

1.1 Technical Scope of Work

TECHNICAL SCOPE OF WORK	COMPLIANCE FC, PC, NC	REMARKS
3.1 General Scope of Work		
The following chapters provide an overview by describing the high-level scope of the project. The more detailed scoping shall be part of the proposal. (If there is a conflict between this chapter and the other more detailed chapters in this document, the latter takes precedence.) The Solution covers the following high-level scope:		
3.1.1 Propose a fully cloud-delivered SASE architecture for internet traffic security that includes centralized management, redundancy, AI-powered threat prevention, and consistent policy enforcement for both managed and BYOD users.	FC	
3.1.2 Provide a SASE solution that converges Secure Web Gateway (SWG), Firewall-as-a-Service (FWaaS), Remote Browser Isolation (RBI) / Enterprise Browser, and DNS Security into a unified cloud-delivered platform.	FC	
3.1.3 Provide a detailed plan for deploying the SASE solution across all campuses, the primary DC, DR site, and integration with local internet breakout links at each campus.	FC	
3.1.4 Support both agent-based deployment for managed (institution-owned) endpoints and agentless deployment for BYOD (personally-owned) endpoints with differentiated security policies.	FC	
3.1.5 Provide AI-powered security capabilities including real-time threat detection, zero-day malware prevention, phishing detection, user and entity behaviour analytics (UEBA), and generative AI application controls.	FC	
3.1.6 Plan for migrating existing legacy on-premises SASE for BYOD users and consolidating with the existing cloud-based solution for managed users into a single platform.	FC	
3.1.7 Include inline SSL/TLS inspection (TLS 1.2 and TLS 1.3) using HCT local CA signed certificate, content filtering, application control, and advanced threat prevention for all internet-bound traffic.	FC	

3.1.8 Real-time monitoring, reporting, and Digital Experience Monitoring (DEM) of user experience, network performance, security incidents, and other metrics.	FC	
3.1.9 Provide necessary training for IT staff on the SASE solution and create detailed documentation.	FC	
3.1.10 Support secure internet breakouts at the campus level via IPsec tunnel-based traffic steering from campus edge devices (NGFW or SD-WAN appliances) to the nearest SASE Point of Presence (PoP).	FC	
3.1.11 Enable agentless BYOD security through DNS-layer security, PAC file distribution, certificate-based authentication, and Remote Browser Isolation without requiring endpoint agent installation.	FC	
3.1.12 Provide granular visibility and control over sanctioned and unsanctioned SaaS application usage, shadow IT discovery, and tenant-level restrictions for multi-tenant SaaS platforms.	FC	
3.1.13 Provide granular controls for generative AI application usage including discovery, per-application policies, and AI usage analytics.	FC	
3.1.14 Integration with existing on-premises infrastructure including Identity Provider (IdP), Network Access Control (NAC), Next-Generation Firewall (NGFW), Endpoint Detection and Response (EDR/XDR), SIEM/SOAR, and Unified Endpoint Management (UEM/MDM).	FC	
3.1.15 Simplified operations with centralized cloud management console and integration with HCT's existing managed SOC.	FC	
3.1.16 Support compliance requirements applicable to education institutions including FERPA, NIST CSF, ISO 27001, PCI-DSS, and UAE data protection regulations.	FC	
3.1.17 (Optional) Provide Zero Trust Network Access (ZTNA) capabilities within the same SASE platform to enable secure, identity-aware, application-level access to on-premises/cloud and datacenter-hosted private applications for up to 200 designated users, without exposing the corporate network or requiring traditional VPN connectivity.	FC	

3.1.18 (Optional) The ZTNA solution must follow a broker-based architecture where the user's device connects to the SASE cloud, the cloud authenticates and authorizes the user and then proxies the connection to the private application via a lightweight connector deployed inside HCT's network. At no point should the user's device have direct network-layer access to HCT's internal network.	FC	
3.1.19 (Optional) The ZTNA solution must support both agent-based access (via the same unified SASE agent used for internet security) and browser-based clientless access for specific web applications, enabling access from both managed and approved unmanaged devices.	FC	
3.1.20 (Optional) All ZTNA access must be governed by the same centralized management console, policy engine, and logging infrastructure as the base SASE internet security platform. No separate management consoles or policy frameworks for ZTNA.	FC	
3.2 Secure Web Gateway (SWG) Requirements		
3.2.1 The SASE platform must provide inline Secure Web Gateway capabilities for all HTTP/HTTPS internet-bound traffic from both managed and BYOD users.	FC	
3.2.2 Full inline SSL/TLS decryption using HCT local CA signed certificate and re-encryption of TLS 1.2 and TLS 1.3 traffic with configurable bypass policies for sensitive categories (banking, healthcare portals) and certificate-pinned applications.	FC	
3.2.3 Granular URL categorization with a minimum of 85 content categories. Must support allow, block, caution, and isolate actions per category. Real-time re-categorization of newly observed URLs using AI/ML.	FC	
3.2.4 Inline file scanning with multi-engine antivirus, heuristic analysis, and advanced cloud-based sandbox detonation for unknown files (PE, Office, PDF, archive formats). Must support both managed and BYOD traffic streams.	FC	
3.2.5 File type control (block uploads/downloads by file type), MIME type inspection, and configurable Safe Search	FC	

enforcement for Google, Bing, YouTube, and other search engines.		
3.2.6 Application-aware bandwidth management with the ability to throttle or prioritize traffic by category (e.g., limit streaming media during academic hours, prioritize LMS and e-learning traffic).	FC	
3.2.7 Customizable block pages and coaching pages that inform users of policy violations with institution branding and acceptable use policy references.	FC	
3.2.8 DNS Security: Inspection and control of DNS traffic (including DNS-over-HTTPS and DNS-over-TLS) to detect and block DNS tunnelling, DGA domains, newly registered domains, and known malicious domains.	FC	
3.2.9 Advanced Browser Threat Protection: AI inspection of fully rendered web content (post-DOM construction) to detect threats that evade traditional proxy-based inspection, including JavaScript-based credential theft, post-load payload assembly, and browser exploitation.	FC	
3.2.10 Encrypted Traffic Analysis: AI/ML analysis of encrypted traffic metadata (JA3/JA4 fingerprints, certificate attributes, traffic patterns) to detect malicious communications without decryption where decryption is not possible or desirable.	FC	
3.2.11 TLS inspection exemption by site reputation database, web categories, and/or policy addresses. Support for TLS Man-in-the-Middle (MITM) mirroring for forensic analysis.	PC	Zscaler supports exemptions based on web categories, and IP/FQDN Addresses, but not by site reputation. Zscaler as a cloud proxy cannot mirror raw decrypted packet streams back to local forensic tools. Zscaler does offer a packet capturing feature allowing In depth Forensic and Threat Hunting. Packet capture license is not part of the proposed license.
3.2.12 Proxy avoidance prevention: Proxy site category blocking, rate URLs by domain and IP address, block redirects from cache and translation sites, proxy avoidance application blocking, proxy behavior blocking.	FC	
3.3 Firewall-as-a-Service (FWaaS) Requirements		

3.3.1 The SASE platform must provide cloud-delivered NGFW-equivalent capabilities for all internet-bound traffic.	FC	
3.3.2 Layer 7 application identification and control, supporting a minimum of 5,000 applications and protocols. Must include the ability to differentiate between sub-applications (e.g., allow Teams chat but block Teams file transfer).	FC	
3.3.3 Inline signature-based and anomaly-based Intrusion Prevention System (IPS) with automatic signature updates. Coverage for OWASP Top 10, CVE-based exploits, and protocol anomalies. Support for a minimum of 13,000 regular and rate-based IPS signatures.	FC	
3.3.4 Support IP, FQDN, Device-based and User/Group-based firewall policies.	FC	
3.3.5 Support for configuring firewall deny policies based on IP Reputation for known public IPs belonging to Botnet-C&C servers, Phishing Servers, Proxy Servers, Spam Servers, TOR Exit nodes and TOR Relay nodes. Updated as signatures from the vendor.	FC	
3.3.4 Support for retrieving External Block List for Domain Names, Web Filtering URLs, IP Addresses and Malware Hashes as Object/Profile settings for use in firewall policies.	FC	
3.3.5 Geo-IP Filtering: Ability to allow or block traffic based on source and destination country, with configurable exception lists.	FC	
3.3.6 Protocol enforcement (HTTP protocol validation, SSH version control) and blocking of non-standard protocol usage over standard ports.	FC	
3.3.7 Detection of traffic using HTTP/3 protocol and ability to block QUIC traffic so that the browser automatically falls back to HTTP/3 + TLS 1.2, TLS 1.3 for inspection purposes.	FC	
3.3.8 DNS-based filtering of Security Risk website categories including Dynamic DNS, Malicious websites, Newly Observed Domains, Newly Registered Domains, Phishing and Spam domains.	FC	
3.3.9 Botnet server IP-based blocking with global IP reputation database. Support for Botnet Domain-based blocking to filter known Fast Flux Botnet Domains.	FC	

3.4 Remote Browser Isolation (RBI)/ Enterprise Browser Requirements		
3.4.1 Pixel-Based Isolation: Execution of web content in an isolated cloud container with only rendered pixels streamed to the user endpoint. No active web content (JavaScript, Flash, ActiveX) should reach the endpoint.	FC	
3.4.2 Policy-Driven Isolation: Ability to selectively isolate web sessions based on URL category (e.g., isolate all uncategorized and newly registered domains), user risk score, or device posture.	FC	
3.4.3 Read-Only Mode for BYOD: Configurable read-only browser sessions that prevent copy, paste, download, upload, and printing from isolated sessions for BYOD users accessing sensitive web applications.	FC	
3.4.4 Transparent User Experience: Isolation must be transparent to the end user with minimal latency impact and full support for modern web applications including rich media, single-page applications, and web-based collaboration tools.	FC	
3.4.5 Clientless ZTNA via Browser-Based RBI: For BYOD users requiring access to institutional web applications, the platform must support clientless access via browser-based isolation without requiring endpoint agent installation.	FC	
3.5 AI-Powered Security Requirements		
The SASE platform must leverage artificial intelligence and machine learning across all security functions. The following AI capabilities are mandatory:		
3.5.1 AI-Driven Threat Detection and Prevention		
3.5.1.1 AI-Based Phishing Detection: Real-time analysis of web page content, URL patterns, brand impersonation indicators, and page behavior to detect phishing pages at time of access, including pages that assemble malicious content after initial page load.	FC	
3.5.1.2 Zero-Day Malware Detection: ML-based static and dynamic analysis of files in the inline inspection path to identify previously unseen malware without reliance on signature databases alone.	FC	
3.5.1.3 AI-Powered DNS Threat Detection: Machine learning models that analyse DNS query patterns to identify domain generation	FC	

algorithms (DGA), DNS tunnelling, and suspicious newly observed domains in real time.		
3.5.1.4 Advanced Browser Threat Protection: AI inspection of fully rendered web content (post-DOM construction) to detect threats that evade traditional proxy-based inspection, including post-load malware assembly and browser exploitation.	FC	
3.5.1.5 Encrypted Traffic Analysis: AI/ML analysis of encrypted traffic metadata (JA3/JA4 fingerprints, certificate attributes, traffic patterns) to detect malicious communications without decryption where decryption is not possible.	FC	
3.5.2 AI-Based User and Entity Behavior Analytics (UEBA)		
3.5.2.1 Behavioral Baseline: Continuous learning of per-user and per-group normal internet usage patterns including access times, data volumes, application usage, and geographic patterns.	FC	
3.5.2.2 Anomaly Detection: Real-time flagging of deviations from established baselines, such as unusual data upload volumes, access to a typical category, login from anomalous locations, or use of evasion tools (anonymizers, personal VPN services).	FC	
3.5.2.3 Risk Scoring: Dynamic per-user and per-device risk scores that adapt based on observed behavior and are available for policy enforcement (e.g., high-risk users subject to stricter inspection or browser isolation).	FC	
3.5.3 AI-Powered Operational Intelligence		
3.5.3.1 AI-Assisted Policy Recommendations: The platform should analyze traffic patterns and threat data to recommend policy optimizations.	FC	
3.5.3.2 AIOps for Troubleshooting: AI-driven root cause analysis that correlates user experience degradation with network path issues, PoP performance, or policy conflicts to accelerate incident resolution.	FC	
3.5.3.3 Predictive Capacity Management: AI forecasting of traffic volumes and PoP utilization to proactively prevent performance degradation during peak periods (e.g., start of academic term, examination periods).	FC	

3.5.4 Generative AI Application Controls		
3.5.4.1 GenAI Application Discovery: Automated identification and categorization of all generative AI applications (ChatGPT, Gemini, Copilot, Claude, Midjourney, and others) accessed through the platform.	FC	
3.5.4.2 Granular GenAI Policy Controls: Per-application controls that allow differentiated policies, such as: allow ChatGPT for staff but restrict to read-only for students; block file upload to unsanctioned AI tools; allow institutional AI tools with full access.	FC	
3.5.4.3 AI Usage Analytics: Dashboards and reports showing GenAI application adoption, data exposure risk, and policy violations across user groups.	FC	
3.5.4.4 Agentic AI Governance: Visibility into agent-to-tool communications (MCP), intent-aware inspection of interactions and tool requests, and policy controls for agent connectivity.	FC	
3.6 BYOD-Specific Requirements		
3.6.1 PAC File / Proxy Auto-Configuration: Support for browser-level traffic steering via PAC file distribution (through DHCP/WPAD or manual configuration) without endpoint agent installation.	FC	
3.6.2 DNS Redirection: Ability to enforce DNS-layer security by configuring campus DHCP to point BYOD clients to the SASE platform DNS resolvers, providing baseline protection without any agent or proxy configuration.	FC	
3.6.3 IPsec Tunnel from Network Edge: Support for tunnel-based traffic steering from campus routers, firewalls, or SD-WAN appliances to the SASE PoP, capturing all internet traffic from BYOD VLANs transparently.	FC	
3.6.4 Certificate-Based Authentication: Support for BYOD user authentication via certificates distributed through an institutional onboarding portal (SCEP/EST) to provide identity context without requiring a full agent.	FC	
3.6.5 Device Type Differentiation: The platform must distinguish between managed and BYOD devices and apply differentiated security policies accordingly.	FC	

3.6.6 Privacy-Preserving Inspection: For BYOD users, the platform must support selective SSL inspection with configurable bypass categories (personal banking, healthcare) and clear user notification of inspection status.	FC	
3.6.7 Session-Based Controls: Time-based session controls for BYOD (e.g., maximum session duration, re-authentication intervals) to ensure continuous identity verification.	FC	
3.6.8 Guest User Self-Registration: Built-in or integrable captive portal workflow for guest user self-registration with terms-of-use acceptance, time-limited access, and configurable bandwidth quotas.	FC	Zscaler ZIA supports user self-registration workflow, but it does so through a seamless, cloud-to-cloud integration with certified technology partners (such as Cloudi-Fi or SecureW2) rather than building the guest registration/SMS gateway database natively inside the Zscaler portal.
3.7 Managed User-Specific Requirements		
3.7.1 Unified Endpoint Agent: A single lightweight agent that handles all SASE functions (SWG traffic steering, DNS security, certificate management, device posture reporting). The agent must support Windows 10/11, macOS (latest and N-1), iOS, and Android.	FC	
3.7.2 Always-On Connectivity: The agent must enforce always-on tunnel to the SASE PoP with no user ability to disable. Configurable fail-open or fail-close behaviour when the SASE PoP is unreachable.	FC	
3.7.3 Device Posture Assessment: Continuous endpoint posture checks including: OS patch level, endpoint protection agent status (running/updated), disk encryption status, firewall status, domain join status, and certificate validity. Posture results must feed into policy decisions.	FC	
3.7.4 Per-App Traffic Steering: Ability to selectively route specific application traffic through the SASE tunnel while allowing configurable split tunnel for trusted local services (e.g., local printer traffic, campus LAN resources).	FC	
3.7.5 Agent Tamper Protection: Anti-tamper mechanisms preventing users from uninstalling, disabling, or circumventing the agent without administrator credentials.	FC	
3.7.6 Silent Deployment: Support for silent deployment and update via enterprise endpoint management tools (SCCM, Intune, Jamf).	FC	

3.7.7 (Optional ZTNA) For managed users within the 200-user ZTNA scope, the unified SASE agent (Section 3.7.1) must handle both internet traffic steering and ZTNA private application tunnelling. No separate ZTNA agent or client shall be required. The agent must seamlessly route traffic to private applications through the SASE cloud ZTNA broker while simultaneously routing internet traffic through the SWG/ FWaaS inspection path.	FC	
3.7.8 (Optional ZTNA) The agent must support split-tunnel intelligence that can distinguish between: traffic destined for published private applications (routed via ZTNA broker), internet-bound traffic (routed via SWG/FWaaS), and local campus LAN traffic (routed directly, not via SASE). The traffic steering table must be dynamically updated based on the applications published to the user's ZTNA policy.	FC	
3.8 Platform Infrastructure and Performance Requirements		
3.8.1 Global PoP Footprint: The vendor must operate a globally distributed network of Points of Presence. At minimum, PoP presence is required in the UAE and the broader GCC region with sub-30ms latency from all campus locations.	FC	
3.8.2 PoP Redundancy: Automatic failover between PoPs with no user-perceptible disruption. Each PoP must be multi-homed with carrier-diverse internet connectivity.	FC	
3.8.3 Capacity and Scalability: The platform must support the total concurrent user count of the institution (29,000+ users, 45,000 concurrent devices) with no degradation. Architecture must be horizontally scalable.	FC	
3.8.4 Data Residency: Logs and configuration data must be stored within a specified geographic region to meet institutional and regulatory data residency requirements.	FC	Subject to the Zscaler policies.
3.8.5 Uptime SLA: Minimum 99.999% platform availability SLA with financially backed service credits.	FC	Please refer to Zscaler link shared for more details on the SLAs offered - https://www.zscaler.com/legal/sla-support
3.8.6 Latency SLA: Maximum additional latency introduced by the SASE inspection path must not exceed 25ms for SWG/FWaaS and 50ms for full SSL inspection plus sandboxing.	PC	Sandboxing time varies based on file size, file extension, content of the file, behaviour of the file, etc.

3.8.7 Throughput SLA: Per-user throughput must support a minimum of 100 Mbps for managed users and 50 Mbps for BYOD users through the full inspection stack.	FC	
3.8.8 Digital Experience Monitoring (DEM)		
3.8.8.1 End-to-End Path Visibility: Hop-by-hop visibility from endpoint to application, including Wi-Fi, LAN, WAN, SASE PoP, and application response metrics.	FC	
3.8.8.2 Synthetic Monitoring: Configurable synthetic probes to continuously test connectivity and performance to critical internet destinations and SaaS applications.	FC	
3.8.8.3 AI-Powered Root Cause Analysis: Automated correlation of user experience issues with network path anomalies, PoP performance, or application-side degradation.	FC	
3.8.8.4 User Experience Scoring: Per-user and per-application experience scores with historical trending and alerting on degradation.	FC	
3.8.9 (Optional ZTNA) ZTNA Session Establishment: Maximum time from user authentication completion to application session 428 availability shall not exceed 3 seconds for web applications and 5 seconds for thick client/RDP/SSH applications.	FC	
3.8.10 (Optional ZTNA) ZTNA Throughput: Per-user throughput through the ZTNA inspection path must support a minimum 50 Mbps for RDP sessions and 100 Mbps for file transfer operations.	FC	
3.8.11 (Optional ZTNA) ZTNA Latency: Additional latency introduced by the ZTNA brokering path (user → SASE cloud → connector → application) must not exceed 30ms for UAE based users and 80ms for users outside UAE	FC	
3.9 Integration Requirements for Zero Trust Ecosystem		
The SASE platform must integrate with the following existing and planned infrastructure components. Integration capabilities are mandatory requirements for this procurement.		
3.9.1 Identity Provider (IdP) + MFA: SAML 2.0, OIDC, SCIM for user/group provisioning. Must support Azure AD/Entra ID, HCT inhouse F5 SAML, and on-premises AD via federation. MFA enforcement at the SASE layer for every access request. Support for Edu Roam Federation.	FC	

3.9.2 Network Access Control (NAC): Integration via RADIUS CoA, REST API, or syslog to receive device posture and classification signals from the NAC. The SASE platform should accept NAC posture tags to differentiate policy for compliant vs. non-compliant devices.	FC	Achievable via REST API and external automation tool, noting that Zscaler support client posture checks to validate if the device is compliant or not.
3.9.3 Next-Generation Firewall (NGFW): Bi-directional log sharing (syslog/CEF/LEEF), shared threat intelligence (STIX/TAXII), and ability to receive IPsec tunnels from the NGFW for on-premises traffic steering to the SASE PoP.	FC	Zscaler doesn't natively support receiving log from next-generation firewalls, but depending on the use case, Zscaler can consume the relevant data via the REST API interface.
3.9.4 Endpoint Detection and Response (EDR/XDR): API-based integration to receive endpoint risk signals. When the EDR flags a compromised endpoint, the SASE platform must dynamically adjust the access policy (e.g., restrict to isolation-only browsing or block entirely).	FC	
3.9.5 SIEM / SOAR: Real-time log export via syslog (CEF), API, or native connector to enterprise SIEM. Support for common platforms (Splunk, Microsoft Sentinel, QRadar, FortiSIEM, Elastic). SOAR integration for automated response workflows.	FC	
3.9.6 Unified Endpoint Management (UEM/MDM): Query device compliance status (encryption, OS version, patch level) from UEM platforms (Intune, Jamf, VMware WS1) as an input to SASE policy decisions.	PC	Supported with different UEM/MDM on different levels in addition to utilizing Zscaler own device posture checks
3.9.7 Threat Intelligence Platform (TIP): Ingest external threat intelligence feeds (STIX/TAXII 2.1) and institutional indicators of compromise (IoCs) for custom blocklist enforcement.	FC	
3.9.8 ITSM / Ticketing: API integration with ServiceNow, IVANTI, or equivalent ITSM for automated ticket creation on security alerts, and policy violations.	FC	Requires the utilization of an external automation tool
3.9.9 Integrate Microsoft Data Loss Prevention (DLP) with the SASE platform to enforce consistent data protection policies across web, cloud, and private application traffic.	FC	
3.9.10 Integrate Microsoft Defender for Cloud Apps (CASB) with the SASE solution for cloud application visibility, SaaS security, risk-based access control, and policy enforcement.	FC	https://www.zscaler.com/resources/solutions/briefs/zscaler-microsoft-deliver-zero-trust-security.pdf

		https://learn.microsoft.com/en-us/defender-cloud-apps/zscaler-integration
3.9.11 Single e-sign-on: Integration with Windows AD, Microsoft Exchange Server and Terminal Server Agent, RADIUS Accounting message for wireless users, and captive portal authentication for wired users.	FC	
3.9.12 (Optional ZTNA) Privileged Access Management (PAM) Integration: If HCT deploys a PAM solution, the ZTNA platform must support integration via API or SAML to enforce PAM-brokered sessions for RDP/SSH access to sensitive servers. ZTNA session recording logs must be exportable to the PAM platform.	FC	Zscaler ZTNA will be the entry point to allow authorized access to have reachability to HCT's PAM solution.
3.9.13 (Optional ZTNA) DNS-Based Application Routing: The ZTNA platform must support private DNS resolution so that published applications can be accessed via their internal FQDN (e.g., erp.hct.local) rather than requiring IP based configuration. The platform must integrate with HCT's internal DNS servers for name resolution of private application FQDNs.	FC	
3.9.14 (Optional ZTNA) Service Ticket / Approval Workflow Integration: The ZTNA platform should support integration with ITSM (Ivanti or equivalent) for access request workflows, enabling users to request time-limited ZTNA access to specific applications through an approval workflow that automatically provisions and de-provisions access upon approval/expiry.	FC	Utilizing the REST API interface
3.10 Centralized Management and Reporting Requirements		
3.10.1 Single Management Console: All security and policy functions must be configurable and monitorable from a single cloud-based management portal. No separate consoles for separate features.	FC	
3.10.2 Role -Based Access Control (RBAC): Granular RBAC for administrative access with a minimum of read-only, operator, policy-admin, and super-admin roles. Support for SAML/OIDC-based admin authentication via the institutional IdP.	FC	
3.10.3 Policy Hierarchy: Support for hierarchical policy structure (global, regional, site-level, user-	FC	

group- level) with inheritance and override capabilities.		
3.10.4 Change Audit Trail: Immutable audit log of all administrative actions (policy changes, user modifications, configuration changes) with timestamps and administrator identity.	FC	
3.10.5 Real -Time Dashboards: Pre-built and customizable dashboards for security events, user activity, application usage, threat landscape.	FC	
3.10.6 Scheduled and On-Demand Reporting: Configurable scheduled reports (daily, weekly, monthly) and on-demand report generation for compliance, executive summary, threat summary, and incident reports. Export to PDF, CSV, and API-accessible formats.	FC	
3.10.7 Alerting and Notification: Configurable alerting thresholds with notification via email, webhook, syslog, and integration with ITSM platforms.	FC	
3.10.8 API Access: Comprehensive RESTful API for automation, integration, and custom reporting. API must cover policy management, user management, log retrieval, and configuration.	FC	
3.10.9 NOC / SOC View: Centralized monitoring and awareness of threats, events and network/internet activity, with predefined and customized dashboards.	FC	
3.10.10 Log Retention: High storage capacity for log retention up to 12 months of online searchable storage with option for extended archival. Log forwarding to third-party syslog server, CEF server, or SIEM solution.	FC	
3.10.11 Indicator of Compromise (IOC): Scan security logs to identify suspicious traffic patterns, continuously monitor for signs of compromise and present a prioritized list of possible compromised hosts.	FC	
3.10.12 HTML5-based Web UI: The management console should not have any Java, Flash or ActiveX components.	FC	
3.10.13 Integration with 3rd party systems via JSON and XML Web Services API.	FC	
3.10.14 (Optional ZTNA) The management console must provide a dedicated ZTNA dashboard showing: active ZTNA sessions (real-	FC	

time), application-level access summary, connector health and status across Primary DC and DR DC, user access patterns and top applications, session recording playback (for RDP/SSH if enabled), and ZTNA-specific policy violations and security events.		
3.10.15 (Optional ZTNA) ZTNA Access Reports: The platform must generate ZTNA-specific reports including: per-user access audit trail (who accessed what application, when, from where, for how long), per-application access summary, denied access attempts with reason codes, device posture failures that prevented ZTNA access, and data volume transferred per user per application.	FC	
3.11 Managed Support Services		
3.11.1 Dedicated Onsite / offsite with 100% backfill in absence of Resident Engineer.	PC	Help AG will provide a replacement engineer during the planned annual leave (24 working days). Any planned annual leave will be mutually agreed with customer. However, during any sick leaves, public holiday or any unplanned/emergency leaves, a replacement engineer shall not be provided however the remote support will continue from Help AG MSC Services to ensure no impact to the customer services
3.11.2 24x7x365 back-to-back support contract from the principal vendor.	FC	
3.11.3 Carry out all operational activities and platform management including changes, incidents, and availability monitoring.	FC	
3.11.4 24x7x365 monitoring services including alerting system.	FC	
3.11.5 Premium 24x7x365 support with SLA.	FC	
3.11.6 Problem Assessment and Investigation with root cause analysis.	FC	
3.11.7 Change Assessment and Implementation.	FC	
3.11.8 Policy and Configuration Management.	FC	
3.11.9 Policy Optimization and Tuning to ensure optimal resource utilization.	FC	
3.11.10 Patch/Update/Hotfix Implementation covering minor updates.	FC	
3.11.11 Configuration Backup and Restoration.	FC	

3.11.9 Unlimited break-fix support should be provided for any issues or problems.	FC	
3.11.10 The Bidder shall provide maintenance services through qualified, experienced and certified specialists.	FC	
3.11.11 Perform major and minor software/firmware/driver upgrades on a regular basis and keep the systems healthy and operational.	FC	
3.11.12 The bidder should have 24x7x365 Help Desk System, Single Support Contact Number and provide Escalation Matrix and Support Methodology.	FC	
3.11.13 Vendor to provide monthly report containing: Total number of tickets raised, Total number of tickets closed, Total number of tickets breached and reason for the breach, Technology-wise ticket details, RCA for all major incidents and service outages.	FC	
3.11.14 A monthly review meeting should be conducted to discuss the monthly report.	FC	
3.11.15 An Excel sheet with details of all the registered tickets for the month.	FC	
3.11.16 Quarterly preventive maintenance, health checks and Configuration review for in-scope platform components. Vendors provide quarterly configuration review and PM reports with findings, recommendations and implement them.	FC	
3.11.17 Full ownership from local partners without any additional costs to HCT.	FC only as per the defined scope in this technical proposal.	
3.11.18 The vendor shall be responsible for the complete management of the SASE platform. This includes ensuring the platform is fully operational, maintaining health and availability, and managing configurations in alignment with HCT's operational requirements.	FC	
3.11.19 The vendor shall monitor the health, availability, and performance of the SASE platform on a 24/7 basis. The vendor must proactively detect and resolve any issues,	FC	

ensuring timely patch management, security updates, and immediate remediation of faults.		
3.11.20 24x7x365 comprehensive managed support services including simple and advanced configuration changes, customization, etc.	FC	
3.11.21 The vendor shall implement a formal change management process. Any proposed changes shall be evaluated for impact, tested in a non-production environment where possible, and approved by HCT before implementation.	FC	
3.11.22 Vendor should monitor the SASE platform 24x7x365 along with dashboards. All alerts and errors should be acknowledged and mitigated proactively. HCT should have access to the dashboards.	FC	
3.11.23 The vendor shall provide quarterly reports on performance, health, and capacity utilization. These reports shall include any potential risks, bottlenecks, or areas for improvement, along with actionable recommendations.	FC	
3.11.24 The vendor should ensure that all platform management activities comply with industry best practices and relevant regulatory requirements.	FC	
3.11.25 The vendor should provide a comprehensive dashboard covering all platform components to provide live information. Daily health check/status report on or before 7:45 AM on all working days.	FC	https://trust.zscaler.com/zscaler.net/cloud-status
3.11.26 The vendor should take all necessary precautions to ensure that the platform is always free from vulnerabilities/risks. The vendor should ensure that all components are within EoL/EoS expiry dates during the contract period and replace any that crosses EoL/EoS at no additional cost.	FC	
3.11.29 Seasonal and Academic Calendar Considerations		
3.11.29.1 HCT shall provide the vendor with the annual academic calendar at least 60 days before each academic year. The vendor shall use this calendar to plan capacity, staffing, maintenance windows, and change schedules.	FC	

3.11.29.2 Capacity Surge Planning: The vendor shall implement a capacity surge plan aligned with HCT's academic calendar. Pre-provisioned additional capacity must be in place at least 7 days before the following peak periods: start of each semester (registration week), examination periods (mid-term and final exams), graduation and convocation events, and any other periods designated by HCT as critical. The vendor must demonstrate that the SASE PoPs serving HCT can handle at minimum 150% of normal peak load during these periods.	FC	
3.11.29.3 Change Freeze Windows: No platform maintenance, upgrades, policy changes, or configuration modifications shall be performed during examination periods unless explicitly approved in writing by the HCT Infrastructure Team. The change freeze window shall begin 3 business days before the first examination and end 1 business day after the last examination of each examination period.	PC	Zscaler will notify HCT and all other customers utilizing that specific cloud that will get any update, noting that most, if not all, the updates will not impact end-user traffic.
3.11.29.4 The vendor shall adjust staffing and support coverage during critical academic periods, ensuring that at minimum one additional senior engineer is on standby during examination weeks and registration periods.	FC	
3.11.29.5 The vendor shall conduct a pre-semester readiness review at least 14 days before each semester start date, covering: platform health check, capacity validation, certificate expiry review, integration validation, and confirmation that no pending changes or known issues exist.	FC	
3.11.30 End-User Communication Protocol		
3.11.30.1 The vendor shall maintain a dedicated status page accessible to HCT IT staff (not publicly accessible) that displays real-time platform status, active incidents, scheduled maintenance, and historical uptime data.	PC	Zscaler cloud trust portal is displaying in real-time platform status, active incidents, etc., but it's not dedicated to HCT and it's publicly accessible.
3.11.30.2 The vendor shall send proactive notifications to HCT's IT operations team within 15 minutes of detecting any service degradation, platform anomaly, or PoP performance issue that could affect end users, even if the issue has not yet been classified as an incident.	FC	
3.11.30.3 HCT retains sole and exclusive authority over all communications to end users	FC	

(students, staff, faculty, guests). The vendor shall not communicate directly with HCT end users under any circumstances without prior written authorization from HCT.		
3.11.30.4 The vendor shall provide pre-approved communication templates to HCT for the following scenarios: planned maintenance notification, unplanned outage notification, service restoration notification, security incident advisory, and policy change notification. Templates shall be provided within 30 days of contract signing and updated annually.	FC	Zscaler will be communicating that information to our subscribed customers over email Partner to provide the template and provide a templated communication to HCT
3.11.30.5 For P1 and P2 incidents, the vendor shall provide HCT with situation update bulletins every 30 minutes until the incident is resolved or downgraded. Each bulletin must include current status, affected services, estimated time to resolution, and actions being taken.	FC	
3.12 Training Requirements		
3.12.1 The participating bidder to provide OEM official training for all the proposed SASE technologies to HCT IT staff (minimum 4 staff).	FC	As proposed in the detailed bill of materials. Principal vendor terms are applicable to the training offered.
3.12.2 The training must be conducted on the HCT premises.	FC	As proposed in the detailed bill of materials. Principal vendor terms are applicable to the training offered.
3.12.3 Training must cover platform administration, policy configuration, troubleshooting, reporting, and integration management.	FC	As proposed in the detailed bill of materials. Principal vendor terms are applicable to the training offered.
3.12.4 Provide comprehensive online knowledge base, API documentation, and release notes accessible to institutional administrators.	FC	As proposed in the detailed bill of materials. Principal vendor terms are applicable to the training offered.
3.12.5 The vendor shall provide refresher training annually for the duration of the contract at no additional cost to HCT, covering new features, platform updates, and changes to security best practices.	FC	All the new training will be accessible on demand via Zscaler university at no additional cost. Zscaler also conducts multiple user group training throughout the year.
3.12.6 The vendor shall provide a dedicated training lab or sandbox environment that mirrors the production SASE platform for HCT IT staff to practice configuration changes, test policies, and conduct operational drills without impacting the live environment.	FC	

3.12.7 Training materials, manuals, and recorded sessions shall be provided in digital format and remain the intellectual property of HCT for internal use throughout and beyond the contract period.	FC	All the training are available in Zscaler university, and access is granted for free for the relevant users during contract period.
3.12.8 The vendor shall provide incident response drill training at least twice per year, simulating P1 and P2 scenarios to validate the joint HCT-vendor incident response process.	FC	
3.12.9 Knowledge Transfer Program		
3.12.9.1 The vendor shall deliver a structured Knowledge Transfer (KT) program during the first 90 days of the operational phase. This program shall go beyond formal training and shall include documented troubleshooting decision trees for the 20 most common operational scenarios, common issue resolution playbooks with step-by-step procedures, a Day-1 Operations Guide covering all daily, weekly, and monthly operational tasks expected of HCT IT staff, and a Quick Reference Guide for emergency procedures.	FC	
3.12.9.2 Shadowing Sessions: During the first 90 days of the operational phase, the vendor shall provide shadowing opportunities where HCT IT staff work alongside vendor engineers on live operational tasks including incident handling, policy changes, and troubleshooting. A minimum of 40 hours of structured shadowing per HCT staff member shall be provided.	FC	
3.12.9.3 The vendor shall assess the knowledge transfer effectiveness at the end of the 90-day KT period through a practical assessment. If the assessment reveals gaps, the vendor shall provide additional targeted training at no cost until the gaps are closed.	FC	
3.12.9.4 The KT program shall be designed to ensure that HCT IT staff can independently perform Tier 1 and Tier 2 operational tasks (policy adjustments, user troubleshooting, report generation, basic incident triage) without vendor assistance after the 90-day KT period. The vendor remains responsible for Tier 3 and above.	FC	
3.13 Documentation Requirements		

3.13.1 The participating bidder must provide detailed documentation including architectural diagrams, high-level and low-level design documents, as-built drawings, integration topology diagrams, SOP, Runbooks and traffic flow diagrams.	FC	All document deliverables will be in English as per Help AG/ Zscaler templates/ formats.
3.13.2 Complete configuration documentation for all SASE platform components, policies, and integrations.	FC	All document deliverables will be in English as per Help AG/ Zscaler templates/ formats.
3.13.3 Runbook documentation covering standard operating procedures, incident response procedures, and escalation procedures.	FC	All document deliverables will be in English as per Help AG/ Zscaler templates/ formats.
3.13.4 The vendor should provide a complete set of detailed documents to cover all proposed technologies and maintain version controls. Regular updates should be applied.	FC	All the technologies related documents are maintained on the public Zscaler documentation.
3.13.5 The vendor shall maintain a Configuration Management Database (CMDB) or equivalent register of all SASE platform components, policy objects, integration endpoints, and user group mappings. This register must be updated within 5 business days of any change and made available to HCT upon request.	FC	
3.13.6 The vendor shall provide a Security Architecture Document describing the end-to-end security posture of the SASE platform, including encryption standards, key management procedures, data handling practices, and threat model assumptions. This document must be updated annually.	FC	
3.13.7 All documentation shall be delivered in editable formats (Word/Visio/Draw.io) in addition to PDF. HCT shall retain full ownership and unrestricted use rights over all project documentation.	FC	
3.13.8 The vendor shall maintain a Risk Register documenting all identified risks to the SASE platform, their probability, impact, mitigation measures, and risk owners. This register must be reviewed and updated quarterly as part of the governance review.	FC	
3.14 Service Level Agreements		
The following are the minimum acceptable service levels. The vendor shall comply with all SLA targets throughout the contract period. Failure to meet SLA targets shall result in financial penalties as defined in this section.		

3.14.1 Incident Response and Resolution SLA					FC	Help AG is dependent on the principal vendor to provide resolution to cases & hence in cases where there is a dependency with the principal vendor to provide resolution, the principal vendor timelines will be applicable.
SLA Matrix		P1	P2	P3	P4	
Response Time		30 Mins	2 Hrs	4 Hrs	8 Hrs	
Resolution Time		2 Hrs	6 Hrs	16 Hrs	32 Hrs	
Fault Classification		Response Time		Resolution Time		
P1 - Critical (service affecting): Any critical SASE platform outage that results in loss of internet security for users or complete service unavailability.		30 Minutes		2 Hours		
P2 - High (service affecting): Any major degradation of SASE platform performance that affects end user internet security quality or significantly impairs policy enforcement.		2 Hours		6 Hours		
P3 - Medium (partially service affecting): Any medium degradation that has partial impact on end user security quality and impact on service operations.		4 Hours		16 Hours		
P4 - Low (non-service affecting): Any minor degradation that does not have any impact on end user security quality and minimal impact on service operations.		8 Hours		32 Hours		
3.14.2 Incident Management Authority						
3.14.2.1 HCT reserves the sole and exclusive right to override the vendor's incident priority classification. If HCT determines that an incident has been classified at a lower priority than warranted, HCT may reclassify the incident to a higher priority by written notification (email or ticketing system). Upon reclassification, the SLA response and resolution clocks shall reset to the higher priority's requirements from the time of HCT's reclassification.					FC	
3.14.2.2 Ticket Closure Authority: No incident ticket shall be marked as 'Resolved' or 'Closed' without explicit written confirmation from HCT. The vendor may mark a ticket as 'Pending HCT Confirmation' once the vendor believes the issue is resolved, but the SLA resolution clock continues until HCT provides confirmation. If HCT does not respond within 3 business days of the vendor's confirmation request, the ticket may be auto-closed but must be re-opened immediately if HCT reports the issue persists.					FC	
3.14.2.3 Recurring Incident Escalation: If the same or substantially similar incident recurs three (3) or more times within a rolling 30-day period, the third occurrence shall be automatically escalated to P1 regardless of its individual severity assessment, and the vendor shall perform a comprehensive root cause analysis with a permanent fix plan within 5 business days.					FC	TSM will be the main focal point for this
3.14.2.4 The vendor shall provide HCT with read-only access to the vendor's ticketing system for all HCT-related incidents, enabling HCT to independently verify ticket status, timestamps, and SLA adherence at any time.					FC	
3.14.3 Mandatory Escalation Matrix						

The vendor shall implement the following mandatory escalation ladder. Escalation shall be automatic and require no action from HCT:		FC	The final escalation matrix with specific contacts will be defined with the involvement of the account TSM. https://www.zscaler.com/legal/sla-support																																
<table><tr><th>Escalation Level</th><th>Trigger</th><th>Vendor Action Required</th><th>Timeframe</th></tr><tr><td>Level 1</td><td>P1 ticket opened</td><td>Assigned engineer + vendor duty manager notified</td><td>Immediate</td></tr><tr><td>Level 2</td><td>P1 not resolved within 2 hours</td><td>Vendor Regional Technical Director joins bridge call with HCT</td><td>2 Hours</td></tr><tr><td>Level 3</td><td>P1 not resolved within 4 hours</td><td>Vendor VP of Engineering / CTO engaged; dedicated war room established</td><td>4 Hours</td></tr><tr><td>Level 4</td><td>P1 not resolved within 8 hours</td><td>Vendor Country Manager / Regional GM engaged; written action plan submitted to HCT</td><td>8 Hours</td></tr><tr><td>Level 5</td><td>P1 not resolved within 24 hours</td><td>Vendor CEO / Global Head of Operations engaged; formal incident review with HCT leadership</td><td>24 Hours</td></tr><tr><td>Level 2 (P2)</td><td>P2 not resolved within 6 hours</td><td>Vendor Technical Director engaged</td><td>6 Hours</td></tr><tr><td>Level 3 (P2)</td><td>P2 not resolved within 16 hours</td><td>Vendor Regional Director engaged with action plan</td><td>16 Hours</td></tr></table>		Escalation Level	Trigger	Vendor Action Required	Timeframe	Level 1	P1 ticket opened	Assigned engineer + vendor duty manager notified	Immediate	Level 2	P1 not resolved within 2 hours	Vendor Regional Technical Director joins bridge call with HCT	2 Hours	Level 3	P1 not resolved within 4 hours	Vendor VP of Engineering / CTO engaged; dedicated war room established	4 Hours	Level 4	P1 not resolved within 8 hours	Vendor Country Manager / Regional GM engaged; written action plan submitted to HCT	8 Hours	Level 5	P1 not resolved within 24 hours	Vendor CEO / Global Head of Operations engaged; formal incident review with HCT leadership	24 Hours	Level 2 (P2)	P2 not resolved within 6 hours	Vendor Technical Director engaged	6 Hours	Level 3 (P2)	P2 not resolved within 16 hours	Vendor Regional Director engaged with action plan	16 Hours		
Escalation Level	Trigger	Vendor Action Required	Timeframe																																
Level 1	P1 ticket opened	Assigned engineer + vendor duty manager notified	Immediate																																
Level 2	P1 not resolved within 2 hours	Vendor Regional Technical Director joins bridge call with HCT	2 Hours																																
Level 3	P1 not resolved within 4 hours	Vendor VP of Engineering / CTO engaged; dedicated war room established	4 Hours																																
Level 4	P1 not resolved within 8 hours	Vendor Country Manager / Regional GM engaged; written action plan submitted to HCT	8 Hours																																
Level 5	P1 not resolved within 24 hours	Vendor CEO / Global Head of Operations engaged; formal incident review with HCT leadership	24 Hours																																
Level 2 (P2)	P2 not resolved within 6 hours	Vendor Technical Director engaged	6 Hours																																
Level 3 (P2)	P2 not resolved within 16 hours	Vendor Regional Director engaged with action plan	16 Hours																																
3.14.4 Platform Availability SLA		FC	Subject to the principal vendor policies & SLA terms as this is entirely dependent on Zscaler & out of Help AG control.																																
<table><tr><th>SLA Metric</th><th>Target</th><th>Measurement</th></tr><tr><td>Overall Platform Availability</td><td>99.999% (five nines)</td><td>Measured monthly across all PoPs serving HCT traffic</td></tr><tr><td>SWG Availability</td><td>99.999%</td><td>Measured as percentage of time SWG inspection path is operational</td></tr><tr><td>FWaaS Availability</td><td>99.999%</td><td>Measured as percentage of time FWaaS inspection path is operational</td></tr><tr><td>RBI/Enterprise Browser Session Launch</td><td>99.9%</td><td>Measured as percentage of RBI/enterprise browser sessions launched within 3 seconds</td></tr><tr><td>Management Console Availability</td><td>99.9%</td><td>Measured as percentage of time admin console is accessible</td></tr><tr><td>DEM Data Freshness</td><td>< 5 minutes</td><td>Maximum delay between user event and DEM dashboard reflection</td></tr><tr><td>ZTNA Private Access Availability</td><td>99.99%</td><td>Measured as % of time ZTNA brokered sessions can be established</td></tr></table>		SLA Metric	Target	Measurement	Overall Platform Availability	99.999% (five nines)	Measured monthly across all PoPs serving HCT traffic	SWG Availability	99.999%	Measured as percentage of time SWG inspection path is operational	FWaaS Availability	99.999%	Measured as percentage of time FWaaS inspection path is operational	RBI/Enterprise Browser Session Launch	99.9%	Measured as percentage of RBI/enterprise browser sessions launched within 3 seconds	Management Console Availability	99.9%	Measured as percentage of time admin console is accessible	DEM Data Freshness	< 5 minutes	Maximum delay between user event and DEM dashboard reflection	ZTNA Private Access Availability	99.99%	Measured as % of time ZTNA brokered sessions can be established										
SLA Metric	Target	Measurement																																	
Overall Platform Availability	99.999% (five nines)	Measured monthly across all PoPs serving HCT traffic																																	
SWG Availability	99.999%	Measured as percentage of time SWG inspection path is operational																																	
FWaaS Availability	99.999%	Measured as percentage of time FWaaS inspection path is operational																																	
RBI/Enterprise Browser Session Launch	99.9%	Measured as percentage of RBI/enterprise browser sessions launched within 3 seconds																																	
Management Console Availability	99.9%	Measured as percentage of time admin console is accessible																																	
DEM Data Freshness	< 5 minutes	Maximum delay between user event and DEM dashboard reflection																																	
ZTNA Private Access Availability	99.99%	Measured as % of time ZTNA brokered sessions can be established																																	
3.14.5 SLA Measurement and Reporting																																			
3.14.5.1 SLA Measurement Methodology: The vendor shall provide a real-time SLA dashboard accessible to HCT 24x7x365 that displays current and historical availability, latency, throughput, and incident metrics for all SLA-measured components. SLA measurements shall be independently verifiable and not solely based on vendor self-reporting.		FC																																	
3.14.5.2 HCT reserves the right to use its own DEM measurements, third-party monitoring tools, or independent audit results to dispute vendor-reported SLA figures. In the event of a dispute, the vendor must provide raw telemetry data within 5 business days to support their SLA calculations.		FC																																	
3.14.5.3 The vendor shall deliver a formal SLA Performance Report within 5 business days of each calendar month end, including: actual availability per component, latency measurements, incident summary with SLA adherence, service credit calculations, and trend analysis.		FC																																	

3.14.5.4	SLA Exclusions: The vendor may exclude only the following from SLA calculations: (a) scheduled maintenance windows pre-approved by HCT with a minimum of 7 calendar days advance notice, limited to a maximum of 4 hours per month during off-peak hours (Friday/Saturday 00:00-06:00 UAE time); (b) issues directly and demonstrably caused by HCT network infrastructure upstream of the SASE PoP handoff point. No other exclusions shall apply. Vendor internal issues including but not limited to staffing shortages, licensing disputes, sub-processor failures, or cloud infrastructure partner outages shall NOT constitute valid SLA exclusions.	FC	
3.14.5.5	Security Efficacy SLA: The vendor shall report quarterly on false positive rates (target: < 0.1% of inspected sessions), malware detection rates (target: > 99% against industry-standard test suites such as AV-TEST or AMTSO), and mean time to block newly identified threats (target: < 60 seconds for known IoC, < 24 hours for zero-day).	PC	Zscaler offers 100% known Virus Capture Rate, but we don't provide false positive SLAs
3.14.5.6	Chronic SLA Failure: If the vendor fails to meet the overall platform availability SLA (99.999%) for three or more months in any rolling 12-month period, HCT shall have the right to terminate the contract for cause and invoke the Transition Assistance obligations defined in Section 3.23.	FC	Based on the availability SLA in the following: https://www.zscaler.com/legal/sla-support
3.14.6 Financial Penalties and Service Credits			
3.14.6.1	SLA breaches shall be governed in accordance with HCT Contract Terms and Conditions. Any applicable service credits, liquidated damages, penalties, or other contractual remedies arising from non-compliance with the agreed SLAs shall be determined and enforced by the HCT Contracts Team in accordance with HCT policies and procedures.	FC, as per comments	All applicable SLAs to be updated as proposed in Help AG proposal (aligned with HCT RFP). Please note, any applicable penalty metrics for delay/ service credits for Help AG SLAs are to be mutually agreed during contract finalization. All penalties are to be applied as a percentage of the delayed deliverable value only, provided such delays are solely attributed to Help AG & all delay penalties are capped to a maximum of 10% of the contract value only.
3.15 Equipment Delivery or Project Timeline			
3.15.1	The SASE platform deployment, migration from legacy on-premises SASE, and	FC	Any dependency/ delay from customer/ third party is to be excluded.

commissioning should be completed within 3 months from the date of signing the contract.		
3.15.2 A minimum 30-day parallel operation period where both legacy and new platforms operate simultaneously to validate policy parity and performance.	FC	
3.15.3 Policy migration assistance: The vendor must provide tooling or professional services to translate existing on-premises security policies into the new cloud platform format.	FC	
3.15.4 The vendor shall provide a detailed phased migration plan within 15 business days of contract signing, including site-by-site rollout sequence, rollback criteria for each phase, and user communication templates.	FC	
3.15.5 User Acceptance Testing (UAT): Each deployment phase must include a formal UAT period (minimum 10 business days) with defined acceptance criteria. HCT shall have the right to reject any phase that does not meet the documented acceptance criteria, and the vendor shall remediate and re-submit at no additional cost.	FC	
3.15.6 Go -Live Readiness Review: The vendor shall conduct a formal Go-Live Readiness Review with HCT before transitioning from parallel operation to production. This review must demonstrate policy parity, performance baseline compliance, integration validation, and incident response readiness. Go-Live requires formal HCT written sign-off.	FC	
3.15.7 Rollback and Migration Risk Management		
3.15.7.1 The vendor shall develop, document, and test a Rollback Plan for each migration phase before that phase begins. The rollback plan must be executable within 4 hours and must restore full service on the legacy platform with no data loss and no user-perceptible disruption beyond the rollback window.	FC	
3.15.7.2 Rollback Triggers: The rollback plan shall define specific, measurable triggers that automatically initiate rollback, including but not limited to: (a) internet latency increase of more than 20% over pre-migration baseline for more than 30 minutes; (b) policy enforcement failure rate exceeding 1% of inspected sessions; (c) more	FC	

than 5% of users unable to access internet resources; (d) any P1 incident on the new platform not resolved within the P1 resolution SLA; (e) any integration failure with IdP, NAC, or SIEM that is not resolved within 4 hours.		
3.15.7.3 The vendor shall maintain the legacy on-premises SASE platform in a fully operational state during the entire parallel operation period and for a minimum of 60 days after HCT provides formal written confirmation that the new platform is operating satisfactorily. Decommissioning of the legacy platform shall only occur after HCT provides explicit written authorization.	FC	
3.15.7.4 The vendor shall conduct a rollback drill (simulated rollback on a non-production segment) before commencing the first production migration phase, to validate that the rollback procedure works as documented. Results of the drill must be shared with HCT.	FC	
3.15.8 Pre-Deployment Performance Baseline		
3.15.8.1 Before the SASE platform goes live on any campus, the vendor shall measure and document the current baseline performance at that campus, including: internet round-trip latency to top 20 internet destinations, throughput (download/upload) for managed and BYOD users, application response times for HCT's top 10 SaaS applications (LMS, Google Workspace, Microsoft 365, etc.), DNS resolution time, user experience scores from the existing DEM or synthetic probes, and Wi-Fi to internet path performance metrics.	FC	
3.15.8.2 Post-deployment, the vendor shall repeat the same baseline measurements within 7 days of go-live on each campus. The SASE platform must not degrade any baseline metric by more than 10%. If any metric is degraded by more than 10%, the vendor must provide a remediation plan within 3 business days and remediate within 10 business days or a rollback shall be triggered.	FC	
3.15.8.3 The pre-deployment and post-deployment baseline measurements shall be compiled into a Performance Baseline Report for each campus, signed by both HCT and the vendor, and shall serve as the reference for ongoing	FC	

performance SLA compliance throughout the contract.		
3.15.9 Legacy Platform Decommissioning		
3.15.9.1 The vendor shall provide a comprehensive Legacy Decommissioning Plan covering: (a) data migration and archival from the legacy platform (logs, reports, historical analytics) to ensure continuity of audit trail; (b) license termination coordination with the legacy vendor (if applicable); (c) configuration export from the legacy platform in a format usable for reference and auditing; (d) validation that no traffic is still flowing through the legacy platform; (e) hardware disposal or repurposing guidance for any on-premises SASE appliances.	FC	
3.15.9.2 The legacy decommissioning shall only proceed after: (a) the new platform has been in production for a minimum of 60 days with all SLAs met; (b) all baseline performance comparisons confirm no degradation beyond 10%; (c) all integrations have been validated on the new platform; (d) HCT provides formal written decommissioning authorization.	FC	
3.15.9.3 The vendor shall provide a formal Decommissioning Completion Certificate to HCT upon completion, confirming that: all legacy data has been migrated or archived, all legacy services have been terminated, and no residual dependencies on the legacy platform remain.	FC	
3.15.10 Liquidated Damages for Project Delays		
3.15.10.1 SLA breaches shall be governed in accordance with HCT Contract Terms and Conditions. Any applicable service credits, liquidated damages, penalties, or other contractual remedies arising from non-compliance with the agreed SLAs shall be determined and enforced by the HCT Contracts Team in accordance with HCT policies and procedures.	FC, as per comment	All applicable SLAs to be updated as proposed in Help AG proposal (aligned with HCT RFP). Please note, any applicable penalty metrics for delay/ service credits for Help AG SLAs are to be mutually agreed during contract finalization. All penalties are to be applied as a percentage of the delayed deliverable value only, provided such delays are solely attributed to Help AG & all delay penalties are capped to a maximum of 10% of the contract value only.

3.15.10.2 Liquidated damages for project delays are separated from and in addition to any operational SLA penalties that may apply after Go-Live.	FC, as per comment	All applicable SLAs to be updated as proposed in Help AG proposal (aligned with HCT RFP). Please note, any applicable penalty metrics for delay/ service credits for Help AG SLAs are to be mutually agreed during contract finalization. All penalties are to be applied as a percentage of the delayed deliverable value only, provided such delays are solely attributed to Help AG & all delay penalties are capped to a maximum of 10% of the contract value only. While Help AG accepts SLA penalties to apply post Go Live, any liquidated damages for delays to be restricted during the implementation phase before Go live only.
3.15.10.3 Delays caused solely by HCT (such as delayed site access, delayed approvals, or changes in scope requested by HCT) shall not be attributable to the vendor. All other delays, including those caused by vendor sub-contractors, resource availability, or vendor technology issues, shall be the vendor's responsibility.	FC	
3.16 Special Terms and Conditions		
3.16.1 Contract Duration and Commercial Terms		
3.16.1.1 The contract shall be for 3 years from the date of signature.	FC	
3.16.1.2 The payment shall be made on a yearly basis over 3 years based on the successful completion and acceptance of each site.	PC	While Help AG accepts annual payment for the products/ licenses & vendor support offered, the yearly invoicing will commence from the product delivery itself & not from successful completion of each site. Please refer to Help AG commercial proposal for more details on the payment milestones offered.
3.16.1.3 Warranty and support for all subscriptions, licenses, and cloud services should be included for 3 years without any additional cost to HCT.	FC	As per the proposed BOQ only
3.16.1.4 HCT has the option to decide to renew/extend this contract at the end of the contract for the same cost.	PC	This is subject to the principal vendor pricing policies.
3.16.1.5 Price Lock: The vendor shall not increase the subscription, licensing, or service	FC, as per comment	The prices offered are valid for the contract term for 3 years.

fees for the duration of the 3-year contract. Any additional users, campuses, or capacity increases during the contract period shall be priced at or below the per-unit rates in the original contract.		However any prices for additional users/ campuses/ capacity increases will be treated as a change request & will be subject to the pricing as offered by the principal vendor.
3.16.1.6 Benchmarking Right: At the end of Year 3, HCT reserves the right to commission an independent benchmarking exercise to compare the vendor's pricing and service capability against current market offerings. If the benchmarking exercise demonstrates that the vendor's pricing is more than 15% above the market median for comparable SASE services, the vendor shall negotiate in good faith to align pricing within 10% of the market median.	PC	This is subject to the principal vendor pricing policies.
3.16.2 Payment Milestones Payments shall be tied to the successful completion and formal acceptance of defined milestones:		<u>Partially compliant</u> Help AG has proposed annual payment for the licenses/ vendor support while quarterly payments are offered for Help AG MSC services. Please refer to our commercial proposal for more details on the payment terms offered.
3.16.3 Vendor Certifications and Compliance		
3.16.3.1 The vendor must hold current ISO 27001, SOC 2 Type II, and CSA STAR certifications for the SASE platform and its supporting infrastructure.	FC	
3.16.3.2 The vendor shall maintain all required certifications (ISO 27001, SOC 2 Type II, CSA STAR) throughout the entire contract duration. Renewed certificates must be provided to HCT within 30 days of issuance. Loss of any certification shall be reported to HCT within 5 business days and shall constitute grounds for termination for cause if not remediated within 90 days.	FC	
3.16.3.3 The vendor shall provide HCT with the annual SOC 2 Type II audit report within 30 days of its completion. If any material findings or qualifications are identified, the vendor shall provide a remediation plan within 15 business days.	FC	
3.16.4 Data Protection and Encryption		
3.16.4.1 Data Encryption: All data in transit between endpoints and the SASE PoP must be encrypted using TLS 1.2 or higher. All	FC	

data at rest (logs, configuration, cached content) must be encrypted using AES-256 or equivalent.		
3.16.4.2 The vendor must provide a Data Processing Agreement (DPA) that complies with UAE Federal Decree-Law No. 45 of 2021 (Personal Data Protection Law), EU GDPR (where applicable to international data transfers), and any other applicable local data protection regulations.	FC	
3.16.4.3 Data Classification Alignment: The vendor shall treat all HCT traffic metadata, logs, user identity information, and platform configurations in accordance with HCT's internal data classification policy. The vendor shall implement appropriate access controls, retention periods, and handling procedures for each classification level.	FC	
3.16.4.4 Data Sovereignty: HCT logs, metadata, and configuration data shall not be stored, processed, or transferred outside of the UAE/GCC region. The vendor shall provide written confirmation of all data storage locations and notify HCT 90 days in advance of any proposed change in data storage geography.	PC	
3.16.4.5 Key Management: Encryption keys used for HCT data shall be managed in accordance with industry's best practices (NIST SP 800-57). Where technically feasible, the vendor shall support customer-managed encryption keys (CMEK / BYOK) for HCT log data and configuration backups.	FC	
3.16.4.6 The solution shall support integration with Hardware Security Modules (HSM) for cryptographic key management, in compliance with UAE National Cybersecurity policies and NIST SP 800-57 key management recommendations. Where the SASE platform generates, stores, or manages cryptographic keys (including SSL/TLS inspection certificates, SAML signing certificates, and API authentication keys), the platform must support the use of FIPS 140-2 Level 2 (or higher) validated HSMs — whether vendor-managed cloud HSM or HCT-managed on-premises HSM — for key generation, storage, and lifecycle management. The vendor shall confirm HSM integration capability in their proposal and specify which HSM vendors and cloud HSM services (e.g., Azure Key Vault with	FC	

HSM backing, AWS CloudHSM, Thales Luna, Entrust nShield) are supported.		
3.16.5 Sub-Processor and Fourth-Party Governance		
3.16.5.1 The vendor shall disclose to HCT a complete list of all sub-processors and fourth parties involved in delivering the SASE service, including their roles, data access levels, and geographic locations. This list shall be provided prior to contract signing and updated within 30 days of any change.	FC	
3.16.5.2 The vendor shall not engage any new sub-processor or change any existing sub-processor without providing HCT with 60 days written notice and receiving HCT's written approval. HCT reserves the right to object to any sub-processor on reasonable grounds including data protection, geographic, or security concerns.	PC	Zscaler will notify and publish the list of updated sub-processors.
3.16.5.3 The vendor shall ensure that all sub-processors and fourth parties are contractually bound to security, confidentiality, and data protection obligations at least equivalent to those imposed on the vendor under this contract.	FC	
3.16.5.4 The vendor shall remain fully liable to HCT for all acts, omissions, and breaches by its sub-processors and fourth parties. Use of sub-processors does not reduce or limit the vendor's obligations or liabilities under this contract.	FC	
3.16.6 Vendor Personnel and Security		
3.16.6.1 All vendor personnel (including sub-contractors) who will have access to HCT traffic, data, or platform administration shall be subject to background verification checks. The vendor shall provide written confirmation that background checks have been completed for all assigned personnel prior to granting access.	FC	Only as per Help AG HR policies.
3.16.6.2 Key Personnel Clause: The vendor shall identify named Key Personnel (at minimum: Project Manager, Technical Lead, Operations Lead, and Security Lead) assigned to the HCT account. Replacement of any Key Personnel requires 30 days written notice to HCT and HCT's written approval. Replacement personnel must have equal or greater qualifications and experience.	FC	

3.16.6.3	The vendor shall immediately revoke access for any personnel who are no longer assigned to the HCT account and confirm revocation to HCT within 24 hours.	FC	
3.16.6.4	All vendor personnel with administrative access to the SASE platform serving HCT shall complete security awareness training annually. Evidence of training completion shall be provided to HCT upon request.	FC	
3.16.7 Vendor Lock-In Mitigation			
3.16.7.1	The vendor shall use open and industry-standard protocols wherever technically feasible, including but not limited to: SAML 2.0 / OIDC for identity federation, SCIM for user provisioning, CEF / LEEF for log export, STIX / TAXII 2.1 for threat intelligence exchange, syslog (RFC 5424) for event forwarding, RADIUS / RADIUS CoA for network integration, RESTful APIs with OpenAPI/Swagger documentation for automation, and IPsec for tunnel-based traffic steering.	FC	
3.16.7.2	If the vendor uses any proprietary protocols, formats, agents, or data structures that are not based on open standards, the vendor shall: (a) disclose all such proprietary elements to HCT prior to contract signing; (b) document the proprietary protocol or format sufficiently for migration or interoperability purposes; (c) provide a migration guide describing how to export data and configurations from the proprietary format to an open-standard equivalent.	FC	
3.16.7.3	The vendor's endpoint agent shall not create dependencies that persist beyond the contract period. The agent must be fully and cleanly uninstallable from all endpoint operating systems without leaving residual services, drivers, certificates, or registry entries that would impede installation of a replacement solution.	FC	
3.16.7.4	All HCT policies, configurations, user/group mappings, URL category customizations, and integration configurations shall be exportable at any time via API or management console in a machine-readable, vendor-neutral format (JSON, CSV, XML). The vendor shall demonstrate this export capability during the PoC phase (Section 3.24).	FC	

3.16.8 Technology Refresh and Roadmap Alignment		
3.16.8.1 The vendor shall keep HCT on the current-generation SASE platform throughout the 3-years contract duration. If the vendor releases a next-generation platform, HCT shall receive the upgrade at no additional cost, including all migration services required to move from the current to the next-generation platform.	FC	
3.16.8.2 The vendor shall provide HCT with an annual Technology Roadmap Briefing (no later than Q1 of each contract year) covering: planned feature releases for the next 12 months, end-of-life or deprecation notices for any components used by HCT, emerging threat landscape trends and how the platform is evolving to address them, and any planned architectural changes to the SASE platform that may affect HCT's deployment.	FC	
3.16.8.3 New features that fall within the contracted scope (SWG, FWaaS, RBI/Enterprise, DNS Security, AI Security, DEM, Management, Integration) shall be enabled for HCT as they become generally available, at no additional license, subscription, or service cost.	FC	
3.16.8.4 If the vendor's technology roadmap diverges materially from HCT's strategic direction (as determined by HCT in its reasonable discretion), HCT shall have the right to invoke the benchmarking clause (3.16.1.6) at any time rather than waiting until Year 3, and if the divergence cannot be reconciled, HCT may terminate the contract for convenience under Section 3.23.3.1.	PC	Zscaler will notify HCT on yearly basis with the roadmap.
3.16.9 Conflict of Interest Disclosure		
3.16.9.1 The vendor shall disclose to HCT, prior to contract signing and on an annual basis thereafter, any existing or potential conflicts of interest including but not limited to: (a) engagements with other UAE federal or educational entities where HCT's data, configurations, or traffic patterns could be exposed or shared, even in anonymized or aggregated form; (b) partnerships, reseller agreements, or financial relationships with competitors of HCT's existing technology vendors (NAC, NGFW, wireless, IdP, SIEM) that could influence the vendor's integration recommendations or support prioritization; (c) any pending or threatened	FC	

litigation, regulatory action, or investigation that could materially affect the vendor's ability to deliver the contracted services; (d) any financial interest or relationship between the vendor's personnel assigned to the HCT account and HCT employees or contractors.		
3.16.9.2 If a conflict of interest is identified (either through disclosure or discovery), the vendor shall propose mitigation measures within 10 business days. HCT reserves the right to approve, reject, or propose alternative mitigation measures. If the conflict cannot be adequately mitigated, HCT may require replacement of affected vendor personnel or, in severe cases, terminate the contract for cause.	FC	
3.16.10 Testing and Non-Production Environment		
3.16.10.1 The vendor shall provide HCT with a dedicated testing and non-production environment (sandbox / staging tenant) that mirrors the production SASE platform configuration. This environment must be available from the deployment phase through the full contract term at no additional cost.	FC	
3.16.10.2 The testing environment shall be used for: validating policy changes before production deployment, testing new features and platform updates before rollout, conducting integration testing with HCT's security ecosystem (IdP, NAC, NGFW, SIEM, EDR), training and knowledge transfer exercises for HCT IT staff, simulating incident response scenarios and tabletop exercises, and validating major SASE platform upgrades before production activation.	FC	
3.16.10.3 The testing environment must support: a representative subset of production security policies, the ability to generate and inspect test traffic (managed and BYOD profiles), all integration endpoints in test mode, full management console access with the same RBAC model as production, and logging and reporting capabilities for test validation.	FC	
3.16.10.4 The testing environment must be logically isolated from the production environment. No test traffic, test policies, or test configurations shall affect or interact with the production platform.	FC	

3.16.10.5 The vendor shall ensure the testing environment is maintained at the same software version as the production environment, or at the version being evaluated for upgrade, throughout the contract term.	FC													
3.17 Project Management														
3.17.1 The winning bidder must appoint a dedicated PM to ensure that all project management processes are effectively managed in accordance with HCT PMO Policy & procedures and PMBOK (PMI) standards and guidelines.	FC													
3.17.2 The winning bidder shall appoint a Project Manager on site. This individual will head the projects for the duration of the work except by mutual agreement with HCT.	PC	Help AG project manager will be a named resource & not dedicated to HCT & accordingly the PM will visit onsite only as mutually agreed during the project execution.												
3.17.3 Have sufficient authority to make day-to-day decisions on site during the progress of the project without recourse to his/her Head Office.	FC													
3.17.4 The Project Manager shall institute changes in project management processes as necessary to ensure that the project is executed within scope, budget and schedule and at an acceptable level of risk. Specific processes include: • Scope Management • Schedule Management • Cost Management • Quality Management • Staffing Management • Communications Management • Risk Management • Procurement Management • Change Management	FC													
3.17.5 The vendor project manager should be available on a scheduled weekly basis for a meeting to update the HCT representative with vendor work progress and problem resolution. Project Management Office Deliverables:	FC													
<table><tr><th>Deliverable</th><th>Description</th></tr><tr><td>Project Charter</td><td>The main purpose of the Project Charter is to formally acknowledge that a project has approval to begin. It is the authoritative document acknowledging the Project's Executive Sponsor and Business Sponsor signoff to initiate the project.</td></tr><tr><td>Project Scope Statement</td><td>Provide a short concise description of the scope of the project. This document defines what is and what is not in scope for the project.</td></tr><tr><td>Project Schedule</td><td>Schedule is a listing of milestones, activities, and deliverables, usually with intended start and finish dates.</td></tr><tr><td>Project Progress Status Report</td><td>To provide insight into team productivity and project accomplishments over a given time period. The reports will present overall progress, team member activity per project, along with the next steps.</td></tr><tr><td>Documentation</td><td>Provide all the documentation as per Section 3.13.</td></tr></table>			Deliverable	Description	Project Charter	The main purpose of the Project Charter is to formally acknowledge that a project has approval to begin. It is the authoritative document acknowledging the Project's Executive Sponsor and Business Sponsor signoff to initiate the project.	Project Scope Statement	Provide a short concise description of the scope of the project. This document defines what is and what is not in scope for the project.	Project Schedule	Schedule is a listing of milestones, activities, and deliverables, usually with intended start and finish dates.	Project Progress Status Report	To provide insight into team productivity and project accomplishments over a given time period. The reports will present overall progress, team member activity per project, along with the next steps.	Documentation	Provide all the documentation as per Section 3.13.
Deliverable	Description													
Project Charter	The main purpose of the Project Charter is to formally acknowledge that a project has approval to begin. It is the authoritative document acknowledging the Project's Executive Sponsor and Business Sponsor signoff to initiate the project.													
Project Scope Statement	Provide a short concise description of the scope of the project. This document defines what is and what is not in scope for the project.													
Project Schedule	Schedule is a listing of milestones, activities, and deliverables, usually with intended start and finish dates.													
Project Progress Status Report	To provide insight into team productivity and project accomplishments over a given time period. The reports will present overall progress, team member activity per project, along with the next steps.													
Documentation	Provide all the documentation as per Section 3.13.													

3.17.6 Project-to-Operations Handover																																				
3.17.6.1	The vendor shall conduct a formal Project Closure and Operational Handover process at the conclusion of the deployment phase, before the project team is demobilized and responsibility transfers to the vendor's operations team.	FC																																		
3.17.6.2	The Project-to-Operations Handover shall include the following mandatory checklist items, each requiring sign-off from both HCT and the vendor:	FC																																		
<table><tr><th>Handover Item</th><th>Description</th><th>Sign-Off Required</th></tr><tr><td>Documentation Completeness</td><td>All documentation listed in Section 3.13 has been delivered, reviewed, and accepted by HCT.</td><td>HCT IT + Vendor PM</td></tr><tr><td>Integration Validation</td><td>All integrations (Section 3.9) have been tested and validated with bi-directional data flow confirmed.</td><td>HCT IT + Vendor Tech Lead</td></tr><tr><td>Monitoring and Alerting</td><td>All monitoring dashboards, alerting rules, and notification channels are operational and verified.</td><td>HCT IT + Vendor Ops Lead</td></tr><tr><td>Configuration Baseline</td><td>Approved configuration baseline (Section 3.18.2.1) has been established, documented, and signed off.</td><td>HCT IT + Vendor</td></tr><tr><td>Knowledge Transfer</td><td>90-day KT program (Section 3.12.9) has been completed and practical assessment passed.</td><td>HCT IT + Vendor</td></tr><tr><td>Runbooks and Playbooks</td><td>All operational runbooks and incident response playbooks have been delivered and walked through with HCT staff.</td><td>HCT IT + Vendor Ops Lead</td></tr><tr><td>Escalation Contacts</td><td>Complete escalation contact list for vendor operations team provided and verified.</td><td>HCT IT + Vendor Ops Lead</td></tr><tr><td>Backup and Recovery</td><td>Configuration backup procedures tested and verified; restore drill completed successfully.</td><td>HCT IT + Vendor</td></tr><tr><td>SLA Baseline</td><td>SLA measurement baseline established, dashboards operational, and first SLA report generated.</td><td>HCT IT + Vendor Ops Lead</td></tr><tr><td>Open Issues Register</td><td>All known issues documented with severity, owner, and resolution timeline. No open P1 or P2 issues.</td><td>HCT IT + Vendor PM</td></tr></table>		Handover Item	Description	Sign-Off Required	Documentation Completeness	All documentation listed in Section 3.13 has been delivered, reviewed, and accepted by HCT.	HCT IT + Vendor PM	Integration Validation	All integrations (Section 3.9) have been tested and validated with bi-directional data flow confirmed.	HCT IT + Vendor Tech Lead	Monitoring and Alerting	All monitoring dashboards, alerting rules, and notification channels are operational and verified.	HCT IT + Vendor Ops Lead	Configuration Baseline	Approved configuration baseline (Section 3.18.2.1) has been established, documented, and signed off.	HCT IT + Vendor	Knowledge Transfer	90-day KT program (Section 3.12.9) has been completed and practical assessment passed.	HCT IT + Vendor	Runbooks and Playbooks	All operational runbooks and incident response playbooks have been delivered and walked through with HCT staff.	HCT IT + Vendor Ops Lead	Escalation Contacts	Complete escalation contact list for vendor operations team provided and verified.	HCT IT + Vendor Ops Lead	Backup and Recovery	Configuration backup procedures tested and verified; restore drill completed successfully.	HCT IT + Vendor	SLA Baseline	SLA measurement baseline established, dashboards operational, and first SLA report generated.	HCT IT + Vendor Ops Lead	Open Issues Register	All known issues documented with severity, owner, and resolution timeline. No open P1 or P2 issues.	HCT IT + Vendor PM		
Handover Item	Description	Sign-Off Required																																		
Documentation Completeness	All documentation listed in Section 3.13 has been delivered, reviewed, and accepted by HCT.	HCT IT + Vendor PM																																		
Integration Validation	All integrations (Section 3.9) have been tested and validated with bi-directional data flow confirmed.	HCT IT + Vendor Tech Lead																																		
Monitoring and Alerting	All monitoring dashboards, alerting rules, and notification channels are operational and verified.	HCT IT + Vendor Ops Lead																																		
Configuration Baseline	Approved configuration baseline (Section 3.18.2.1) has been established, documented, and signed off.	HCT IT + Vendor																																		
Knowledge Transfer	90-day KT program (Section 3.12.9) has been completed and practical assessment passed.	HCT IT + Vendor																																		
Runbooks and Playbooks	All operational runbooks and incident response playbooks have been delivered and walked through with HCT staff.	HCT IT + Vendor Ops Lead																																		
Escalation Contacts	Complete escalation contact list for vendor operations team provided and verified.	HCT IT + Vendor Ops Lead																																		
Backup and Recovery	Configuration backup procedures tested and verified; restore drill completed successfully.	HCT IT + Vendor																																		
SLA Baseline	SLA measurement baseline established, dashboards operational, and first SLA report generated.	HCT IT + Vendor Ops Lead																																		
Open Issues Register	All known issues documented with severity, owner, and resolution timeline. No open P1 or P2 issues.	HCT IT + Vendor PM																																		
3.17.6.3	The operational handover shall not be considered complete until all check-list items are signed off by both parties. The vendor's project team shall remain available for a minimum of 15 business days after the handover sign-off to address any issues arising from the transition.	FC																																		
3.17.6.4	The vendor shall provide a formal Project Closure Report summarizing: project scope delivered, deviations from the original plan, lessons learned, outstanding items (if any) with timelines, and recommendations for the operational phase.	FC																																		
3.18 Configuration Hygiene and Lifecycle Management																																				
The vendor shall implement a rigorous configuration hygiene program to ensure the SASE platform remains optimized, clean, and free from configuration drift, redundant policies, or orphaned objects throughout the contract period.		FC																																		
3.18.1 Quarterly Configuration Review and Clean-Up																																				
3.18.1.1	The vendor shall conduct a comprehensive configuration audit every quarter. The audit shall cover all policy rules, security	FC																																		

profiles, user/group mappings, application definitions, URL categories, integration endpoints, certificate stores, and all other configurable elements within the SASE platform.		
3.18.1.2 Unused Policy Identification: The vendor shall identify and flag all security policies, firewall rules, and access rules that have not been triggered or matched by any traffic within the preceding 90-day period. A report of these unused policies must be presented to HCT with a recommendation to disable, archive, or delete.	FC	
3.18.1.3 Orphaned Objects Clean-Up: The vendor shall identify and remove all orphaned configuration objects including: user groups no longer referenced by any policy, IP address objects with no policy association, expired certificates, stale DNS entries, unused URL category overrides, disabled integration endpoints, and decommissioned user accounts. A written summary of all objects removed must be provided to HCT.	FC	
3.18.1.4 Redundant and Conflicting Policy Detection: The vendor shall use policy analysis tools (vendor-native or third-party) to identify shadowed rules (rules that can never match due to a higher-priority rule), duplicate rules, overlapping rules with conflicting actions, and overly permissive rules. A detailed report with remediation recommendations must be delivered.	FC	
3.18.1.5 Policy Rule Optimization: The vendor shall review the ordering and specificity of all policy rules and recommend reordering or consolidation to improve inspection efficiency, reduce latency, and tighten the security posture. Any changes must be tested and approved by HCT before implementation.	FC	
3.18.1.6 Certificate and Credential Lifecycle: The vendor shall track all SSL/TLS certificates, SAML certificates, API keys, service accounts, and authentication tokens used by the SASE platform. A quarterly report must list all credentials approaching expiry (within 90 days) and confirm that no expired or revoked credentials remain active.	FC	
3.18.1.7 Integration Health Validation: The vendor shall validate the health and operational status of all integrations (IdP, NAC, NGFW, EDR,	FC	

SIEM, UEM, TIP, ITSM) during each quarterly review. Broken or degraded integrations must be remediated within 5 business days of identification.		
3.18.1.8 (Optional ZTNA) ZTNA Application Review: The quarterly configuration audit must include review of all published ZTNA applications to identify: applications that have had zero access sessions in the preceding 90 days (candidates for de-publishing), applications with excessively broad access policies (more users than required), ZTNA connector capacity and utilization, and any private applications that should be published but are being accessed through alternative paths (e.g., legacy VPN if still active).	FC	
3.18.2 Configuration Baseline and Drift Management		
3.18.2.1 The vendor shall establish and maintain an approved configuration baseline (gold standard) for the SASE platform. The baseline shall be documented, version-controlled, and formally approved by HCT at the end of the deployment phase and after each major change.	FC	
3.18.2.2 Configuration Drift Detection: The platform must support automated detection of deviations from the approved baseline configuration. Any drift detected must generate an automated alert to both vendor operations and HCT IT. The vendor shall remediate unauthorized drift within 4 hours of detection.	PC	The detection is not automated, and will need be checked by the solution admin.
3.18.2.3 Configuration Backup: The vendor shall maintain automated daily configuration backups with a minimum retention of 365 days. The vendor must demonstrate the ability to restore the platform to any previous configuration state within 2 hours for P1 incidents.	FC	
3.18.2.4 Change-Triggered Audit: Every configuration change (whether manual or automated) must be logged with the change requestor, approver, timestamp, description, and before/after configuration diff. These logs must be immutable and available to HCT for audit purposes.	FC	
3.18.3 Quarterly Configuration Review Deliverables		

The vendor shall produce and present the following deliverables at each quarterly configuration review meeting:			FC	Joint activity between the Zscaler TSM and the partner
Deliverable	Description	Deadline		
Configuration Audit Report	Complete audit of all policies, rules, objects, and configurations including unused/orphaned/redundant items identified and remediation status.	Q+10 business days		
Policy Hit Count Analysis	Detailed hit-count analysis for all policies showing usage frequency over the preceding quarter. Zero-hit policies flagged with disposition recommendation.	Q+10 business days		
Certificate & Credential Inventory	Complete inventory of all certificates, API keys, and service accounts with expiry dates and renewal status.	Q+10 business days		
Integration Health Report	Status of all integrations including connectivity test results, data flow validation, and any degradation observed during the quarter.	Q+10 business days		
Configuration Drift Report	Summary of all configuration drift events, their root cause, remediation time, and preventive measures implemented.	Q+10 business days		
Remediation Action Plan	Plan for addressing all findings from the audit including timelines, responsible parties, and risk classification.	Q+15 business days		
3.19 Compliance and Regulatory Requirements				
3.19.1 UAE National Regulatory Compliance				
3.19.1.1 The vendor and the SASE platform shall comply with the UAE Information Assurance (IA) Regulation as published by the Telecommunications and Digital Government Regulatory Authority (TDRA), including all applicable IA controls and standards for federal entities.			FC	
3.19.1.2 The vendor shall demonstrate alignment with the UAE National Cybersecurity Strategy and the requirements of the National Electronic Security Authority (NESA) Compliance Framework as applicable to federal government institutions.				
3.19.1.3 The vendor shall comply with UAE Federal Decree-Law No. 45 of 2021 regarding the Protection of Personal Data, including all requirements for data processing, data transfer, data subject rights, and breach notification.				
3.19.1.4 The vendor shall comply with any directives issued by the UAE Cybersecurity Council that are applicable to the SASE services delivered under this contract.				
3.19.2 International Standards Compliance				
3.19.2.1 The SASE platform and the vendor's operational practices shall support HCT's compliance with the following international standards and frameworks: NIST Cybersecurity Framework (CSF) 2.0, NIST SP 800-171, ISO/IEC 27001:2022, PCI-DSS v4.0 (where applicable),			PC	

FERPA (Family Educational Rights and Privacy Act), CIS Controls v8.		
3.19.2.2 The vendor shall provide compliance mapping documentation showing how the SASE platform's features and controls map to each of the above frameworks. This mapping must be delivered within 60 days of signing the contract and updated annually.	PC	
3.19.3 Compliance Evidence and Reporting		
3.19.3.1 The vendor shall provide to HCT, on an annual basis: renewed ISO 27001 certificate, SOC 2 Type II audit report (full report, not summary), CSA STAR certification, evidence of TDRA/NESA compliance (if applicable), and confirmation of ongoing compliance with UAE data protection law.	PC	
3.19.3.2 The vendor shall notify HCT within 5 business days of any regulatory finding, audit qualification, enforcement action, or investigation by any regulatory authority that relates to the SASE platform or the vendor's security practices.	FC	
3.19.3.3 The vendor shall cooperate fully with any HCT internal audit, external audit, or regulatory examination that requires information about the SASE platform, data handling practices, or security controls.	FC	- Help AG doesn't accept customers/vendors assessments or audits requests, as Help AG goes through regular extensive independent third party audits as part of maintaining its ISO 27001, ISO 22301, ISO 20000, ISO 27035, CREST and SOC CMM Level 3 certifications. - If any audit needs to be conducted, it has to be performed by an independent 3rd party audit firm to maintain the integrity of the audit process and ensure unbiased evaluations -Such audit will require minimum 15 working days' notice and shall not disturb the business or create extraordinary efforts of Help AG -The third party auditor must submit a 'Letter of Engagement' or 'Terms of Reference,' which shall include, but is not limited to, the following points. This document will be reviewed by Help AG's GRC team and will require the COO's approval to proceed with the audit, provided no concerns are raised by the GRC team. - o Purpose of the audit - o Exact audit scope - o Auditors individual names and roles within the organization

		- o Level of access required - o Intended audience of the findings - o Timing and duration - o Methodology and standards to be followed - o Confidentiality terms
3.19.4 HCT Information Security Requirements Baseline	PC	Please refer to the following compliance table with detailed responses on this requirement
3.20 Business Continuity and Disaster Recovery		
3.20.1 Vendor BCP/DRP Requirements		
3.20.1.1 The vendor shall maintain a documented and tested Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP) specific to the SASE platform and the services delivered to HCT. The BCP/DRP must be provided to HCT prior to contract signing and updated annually.	FC	
3.20.1.2 The vendor shall conduct a full BCP/DRP test at least annually and provide HCT with the test results, including scenarios tested, recovery times achieved, and any identified gaps with remediation plans, within 30 days of each test.	PC	Please replace "within 30 days of each test" with "upon HCT's request."
3.20.1.3 Recovery Time Objective (RTO): The vendor shall commit to a maximum RTO of 4 hours for complete platform restoration following a catastrophic failure of any single PoP or data centre serving HCT traffic.	FC	Subject to any Force Majeure events & principal vendor policies.
3.20.1.4 Recovery Point Objective (RPO): The vendor shall commit to a maximum RPO of 1 hour for configuration data, policy data, and log data. No configuration or policy changes committed within the RPO window shall be lost.	FC	Subject to any Force Majeure events & principal vendor policies.
3.20.1.5 The vendor's BCP/DRP must address the following scenarios at minimum: (a) complete failure of a single PoP; (b) simultaneous failure of all PoPs in a geographic region; (c) control plane failure (management console unavailable while data plane continues); (d) vendor cloud infrastructure provider outage; (e) major cybersecurity incident affecting the vendor's own infrastructure; (f) vendor personnel unavailability (pandemic, strike, mass resignation).	FC	
3.20.2 Regional PoP Resilience		

3.20.2.1 The vendor shall maintain a minimum of two (2) geographically separated Points of Presence within the UAE/GCC region, each capable of independently handling 100% of HCT's traffic volume.	FC	
3.20.2.2 Automatic failover between regional PoPs must occur within 60 seconds with no user- perceptible disruption and no loss of active sessions. The failover mechanism must be tested quarterly and results shared with HCT.	FC	The failover test to be covered by the partner.
3.20.2.3 The vendor shall notify HCT within 30 minutes of any PoP degradation or failover event and provide a full incident report within 24 hours.	FC	
3.20.2.4 (Optional ZTNA) ZTNA Connector Resilience: The BCP/DRP must address ZTNA connector failure scenarios. If all connectors in the Primary on-premises or cloud DC fail, traffic must automatically failover to on-premises or cloud DR DC connectors within 60 seconds. The vendor must demonstrate this failover during the PoC or deployment phase.	FC	
3.20.2.5 (Optional ZTNA) ZTNA Fallback: If the ZTNA cloud broker is unavailable for an extended period (> 1 hour), the vendor must provide a documented fallback procedure that allows HCT to temporarily grant direct VPN or alternative access to critical private applications for the 200 ZTNA users, without requiring vendor involvement. This fallback must be pre-configured and tested during deployment.	FC	
3.20.3 HCT Emergency Bypass		
3.20.3.1 The vendor shall design the architecture to allow HCT to bypass the SASE inspection path in an emergency scenario without vendor involvement. The bypass mechanism must be documented, tested during deployment, and controlled by HCT IT staff via a pre-configured procedure.	FC	
3.20.3.2 The emergency bypass procedure must include defined criteria for when bypass is authorized, which HCT personnel can authorize it, the method of re-engaging SASE inspection after the emergency, and a maximum bypass duration policy.	FC	

3.20.3.3	The vendor shall provide HCT with a 'break glass' administrator account that is independent of the vendor's normal authentication infrastructure and can be used by HCT to access the SASE management console even if the vendor's identity systems are unavailable.	FC																					
3.20.4	Force Majeure																						
3.20.4.1	Force majeure events shall be limited to: natural disasters, acts of war or terrorism, government-mandated shutdowns, and events genuinely beyond the reasonable control of the affected party. The following shall NOT constitute force majeure: vendor staffing shortages, vendor sub-contractor or sub-processor failures, vendor licensing or commercial disputes with their OEM or technology partners, vendor cloud infrastructure provider outages (unless caused by a qualifying force majeure event), or vendor financial difficulties.	FC																					
3.20.4.2	In the event of a force majeure, the affected party shall notify the other party within 24 hours, provide a detailed mitigation plan within 48 hours, and use all reasonable efforts to resume normal service. If a force majeure event persists for more than 30 consecutive days, either party may terminate the contract with 30 days written notice.	FC	In any case of termination, customer will be liable for payment of all delivered products/ licenses & vendor support for the entire contract term & Help AG services delivered until the effective date of termination.																				
3.21 Governance Framework																							
The vendor and HCT shall establish a formal governance framework for the duration of the contract. The governance structure shall operate at three levels:		FC																					
<table><tr><th>Governance Level</th><th>Frequency</th><th>Participants (Vendor)</th><th>Participants (HCT)</th><th>Scope</th></tr><tr><td>Operational Review</td><td>Monthly</td><td>Operations Lead, Technical Lead</td><td>IT Infrastructure Team</td><td>Ticket review, SLA performance, incident analysis, configuration changes, upcoming maintenance</td></tr><tr><td>Service Management Review</td><td>Quarterly</td><td>Account Manager, Operations Lead, Technical Director</td><td>Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network, Specialist Network & Security</td><td>SLA trends, capacity planning, configuration audit review, risk register update, roadmap alignment, vendor scorecard review</td></tr><tr><td>Strategic Steering Committee</td><td>Bi-Annual</td><td>Country Manager / Regional Director, Account Director, Technical Director</td><td>Director IT, Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network</td><td>Contract performance, strategic alignment, technology roadmap, escalated issues, benchmarking results, annual business review</td></tr></table>		Governance Level	Frequency	Participants (Vendor)	Participants (HCT)	Scope	Operational Review	Monthly	Operations Lead, Technical Lead	IT Infrastructure Team	Ticket review, SLA performance, incident analysis, configuration changes, upcoming maintenance	Service Management Review	Quarterly	Account Manager, Operations Lead, Technical Director	Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network, Specialist Network & Security	SLA trends, capacity planning, configuration audit review, risk register update, roadmap alignment, vendor scorecard review	Strategic Steering Committee	Bi-Annual	Country Manager / Regional Director, Account Director, Technical Director	Director IT, Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network	Contract performance, strategic alignment, technology roadmap, escalated issues, benchmarking results, annual business review		
Governance Level	Frequency	Participants (Vendor)	Participants (HCT)	Scope																			
Operational Review	Monthly	Operations Lead, Technical Lead	IT Infrastructure Team	Ticket review, SLA performance, incident analysis, configuration changes, upcoming maintenance																			
Service Management Review	Quarterly	Account Manager, Operations Lead, Technical Director	Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network, Specialist Network & Security	SLA trends, capacity planning, configuration audit review, risk register update, roadmap alignment, vendor scorecard review																			
Strategic Steering Committee	Bi-Annual	Country Manager / Regional Director, Account Director, Technical Director	Director IT, Senior Manager IT Infrastructure, Manager - Network & Telecom, Assistant Manager - Network	Contract performance, strategic alignment, technology roadmap, escalated issues, benchmarking results, annual business review																			
3.21.1 Vendor Performance Scorecard																							
3.21.1.1 The vendor shall be assessed quarterly against the following Key Performance Indicators (KPIs). The scorecard results shall be		FC																					

presented at the quarterly Service Management Review and form part of the annual strategic review:

KPI Category	KPI Metric	Target	Measurement Method
Availability	Platform uptime (SLA adherence)	> 99.999%	Vendor SLA dashboard + HCT DEM validation
Incident Management	P1/P2 SLA adherence rate	> 98%	Ticket system analysis
Incident Management	Mean Time to Detect (MTTD)	< 5 minutes	SIEM correlation and alert timestamps
Incident Management	Mean Time to Respond (MTTR)	Per SLA matrix	Ticket system analysis
Security Efficacy	False positive rate	< 0.1%	Quarterly sampling and analysis
Security Efficacy	Threat detection rate	> 99%	AMTSO/AV-TEST benchmarking
Operations	Change success rate	> 99%	Change records / rollback analysis
Operations	Configuration drift incidents	< 2 per quarter	Drift detection alerts
Operations	Quarterly config review completion	100%	Deliverable tracking
User Experience	User experience score (DEM)	> 85/100	DEM platform scoring
User Experience	Latency SLA adherence	100%	DEM and synthetic monitoring
Reporting	Monthly report on-time delivery	100%	Report delivery date tracking
Training	Annual training delivery	100%	Training records

3.21.2 Dispute Resolution

3.21.2.1 Disputes arising under this contract shall be resolved through the following escalation ladder:

(a) Level 1 – Operational teams (vendor Operations Lead and HCT Assistant Manager/Manager) shall attempt to resolve the dispute within 5 business days; (b) Level 2 – If unresolved, escalate to senior management (vendor Account Director and HCT Senior Manager IT Infrastructure) within 10 business days; (c) Level 3 – If still unresolved, escalate to executive management (vendor Country Manager and HCT Director IT) within 15 business days; (d) Level 4 – If still unresolved, the parties shall submit the dispute to formal mediation under the rules of the Abu Dhabi Commercial Conciliation and Arbitration Centre; (e) Level 5 – If mediation fails, the dispute shall be referred to binding arbitration under UAE law, with the seat of arbitration in Abu Dhabi.

FC

3.21.2.2 During the dispute resolution process, the vendor shall continue to provide all services under this contract without interruption or degradation.

FC

3.21.3 Continuous Improvement

3.21.3.1 The vendor shall propose a minimum of four (4) improvement initiatives per year, aligned with HCT's strategic objectives and industry's best practices.

FC

3.21.3.2 The vendor shall conduct an annual Threat Landscape Review with HCT,

FC

analyzing emerging threats relevant to the higher education sector and recommending adjustments to the SASE security posture accordingly.		
3.22 Audit and Assurance		
3.22.1 HCT Right to Audit		
3.22.1.1 HCT (or a third-party auditor appointed by HCT) shall have the right to audit the vendor's security controls, data handling practices, incident response procedures, compliance posture, and operational processes related to the SASE services delivered under this contract.	PC	Zscaler is being audited by trusted global companies and with the relevant NDA, Zscaler can share audit findings. - Help AG doesn't accept customers/vendors assessments or audits requests, as Help AG goes through regular extensive independent third party audits as part of maintaining its ISO 27001, ISO 22301, ISO 20000, ISO 27035, CREST and SOC CMM Level 3 certifications. - If any audit needs to be conducted, it has to be performed by an independent 3rd party audit firm to maintain the integrity of the audit process and ensure unbiased evaluations - Such audit will require minimum 15 working days' notice and shall not disturb the business or create extraordinary efforts of Help AG - The third party auditor must submit a 'Letter of Engagement' or 'Terms of Reference,' which shall include, but is not limited to, the following points. This document will be reviewed by Help AG's GRC team and will require the COO's approval to proceed with the audit, provided no concerns are raised by the GRC team. - o Purpose of the audit - o Exact audit scope - o Auditors individual names and roles within the organization - o Level of access required - o Intended audience of the findings - o Timing and duration - o Methodology and standards to be followed - o Confidentiality terms
3.22.1.2 Routine audits may be conducted once per year with 30 days written notice. The vendor shall provide full cooperation, including access to documentation, personnel, facilities, and platform data relevant to the audit scope.	PC	Zscaler is being audited by trusted global companies and with the relevant NDA, Zscaler can share audit findings. - Help AG doesn't accept customers/vendors assessments or audits requests, as Help AG goes through regular extensive independent third party audits as part of maintaining its ISO 27001, ISO 22301, ISO 20000,

		ISO 27035, CREST and SOC CMM Level 3 certifications. - If any audit needs to be conducted, it has to be performed by an independent 3rd party audit firm to maintain the integrity of the audit process and ensure unbiased evaluations -Such audit will require minimum 15 working days' notice and shall not disturb the business or create extraordinary efforts of Help AG -The third party auditor must submit a 'Letter of Engagement' or 'Terms of Reference,' which shall include, but is not limited to, the following points. This document will be reviewed by Help AG's GRC team and will require the COO's approval to proceed with the audit, provided no concerns are raised by the GRC team. - o Purpose of the audit - o Exact audit scope - o Auditors individual names and roles within the organization - o Level of access required - o Intended audience of the findings - o Timing and duration - o Methodology and standards to be followed - o Confidentiality terms
3.22.1.3 In the event of a confirmed or suspected security incident, data breach, or material SLA breach, HCT shall have the right to conduct an immediate audit with 48 hours' notice.	PC	Zscaler is being audited by trusted global companies and with the relevant NDA, Zscaler can share audit findings.
3.22.1.4 The vendor shall remediate all audit findings classified as Critical within 15 business days, High within 30 business days, and Medium within 60 business days. The vendor shall provide a remediation action plan within 10 business days of receiving audit findings.	PC	Audit findings will be resolved as soon as it's technically feasible
3.22.1.5 All audit costs shall be borne by HCT for routine annual audits. However, if an audit triggered by a vendor-caused incident or SLA breach reveals material deficiencies, the vendor shall bear the cost of the audit.	NC	
3.22.2 Penetration Testing and Vulnerability Assessment		
3.22.2.1 The vendor shall conduct an independent third-party penetration test of the SASE platform at least annually and provide HCT with the full report within 30 days of test completion.	FC	As per principal vendor policies only.

3.22.2.2 HCT reserves the right to conduct its own penetration testing or vulnerability assessment of the SASE platform interfaces accessible to HCT, with 30 days written notice to the vendor.	FC	Need to follow a request/approve process as this is subject to the principal vendor policies only.
3.22.2.3 The vendor shall maintain a vulnerability management program that ensures: (a) critical vulnerabilities (CVSS >= 9.0) are patched within 48 hours; (b) high vulnerabilities (CVSS 7.0-8.9) are patched within 7 days; (c) medium vulnerabilities (CVSS 4.0-6.9) are patched within 30 days.	FC	
3.22.3 Incident Forensics and Evidence Preservation		
3.22.3.1 In the event of any security incident, the vendor shall preserve all forensic evidence for a minimum of 12 months or until HCT provides written authorization to destroy the evidence, whichever is longer.	FC	
3.22.3.2 The vendor shall provide HCT with a detailed incident timeline within 24 hours of incident detection.	PC	Please change "24 hours" to "3 business days."
3.22.3.3 The vendor shall cooperate fully with HCT's own forensic investigations and any regulatory or law enforcement investigations arising from a security incident.	FC	
3.22.3.3 Data Breach Notification: The vendor shall notify HCT of any confirmed or suspected data breach affecting HCT data within 1 hour of detection.	PC	Please change "1 hour" to "24 hours."
3.22.3.5 The vendor shall maintain online (searchable, queryable) log storage for no less than eight (8) months for all SASE platform logs including: DNS query logs, web access logs, security event logs, firewall logs, RBI/enterprise browser session logs, DEM telemetry, administrative audit logs, and integration event logs. Online logs must be searchable in near-real-time (maximum 5-minute indexing delay) and accessible to HCT administrators via the management console and API. Logs older than 8 months may be moved to archival storage but must remain retrievable within 24 hours upon HCT request for a total retention period of no less than 12 months. Log forwarding to HCT's SIEM via syslog (CEF/LEEF) shall operate in real-time independent of the online retention period.	FC	

3.22.4 Configuration Audit Baseline		
3.22.4.1 The vendor shall establish an approved security configuration baseline at the end of the deployment phase. This baseline shall be documented, cryptographically hashed, and stored for audit comparison purposes.	FC	
3.22.4.2 Any deviation from the approved baseline must be authorized through the formal change management process. Unauthorized deviations shall be treated as a P2 security incident.	FC	
3.22.5 Third-Party Audit Report Sharing		
3.22.5.1 The vendor shall provide HCT with copies of all third-party security assessments, penetration test reports, compliance audit findings, and regulatory examination results that relate to the SASE platform, within 30 days of receipt.	PC	Please replace "within 30 days of receipt" with "upon HCT's request."
3.22.5.2 If any third-party report identifies material findings, the vendor shall provide a remediation plan to HCT within 10 business days.	PC	Audit findings will be resolved as soon as it's technically feasible
3.22.6 Joint Security Exercises		
3.22.6.1 The vendor shall participate in annual joint tabletop exercises with HCT, simulating security incident scenarios including: compromised endpoint exfiltrating data through the SASE platform, SASE platform bypass attempt, and advanced persistent threat targeting HCT users. The exercises shall test the end-to-end detection, response, escalation, and remediation processes.	FC	Only support will be provided from Help AG during the activity.
3.22.6.2 The vendor shall support HCT's own red team exercises. If HCT engages a red team to test the overall security posture, the vendor must cooperate fully and shall not treat red team activity as hostile or use it as grounds for SLA exclusion. The vendor shall be notified of red team exercises in advance under NDA.	FC	Only support will be provided from Help AG during the activity.
3.22.6.3 Findings from tabletop and red team exercises shall be documented and tracked in the Risk Register (Section 3.13.8). The vendor shall implement remediation measures for any identified gaps within agreed timeframes.	FC	

1.2 3.19.4 HCT Information Security Requirements Baseline

5. Information Security Requirements Checklist		Compliance	Remarks
5.1 Information Security Governance & Policy			
5.1.1	The supplier shall maintain a documented Information Security Management System (ISMS) aligned with an internationally recognized standard (e.g., ISO/IEC 27001, NIST CSF, UAE IA) and provide evidence of certification or compliance upon request.	☒ Yes ☐ No ☐ NA	
5.1.2	The supplier shall comply with applicable national cybersecurity policies and regulations issued by the Cyber Security Council (CSC) and provide evidence of adherence upon request.	☒ Yes ☐ No ☐ NA	
5.1.3	The supplier shall have a formally approved Information Security Policy, reviewed and updated periodically or following significant organisational or threat changes.	☒ Yes ☐ No ☐ NA	
5.1.4	The supplier shall designate a named Information Security Officer (ISO) or equivalent role with defined responsibilities for overseeing the security programme. (incident response, vulnerability, patch, BCDR, continuity, etc)	☒ Yes ☐ No ☐ NA	
5.1.5	The supplier shall ensure that roles and responsibilities, and segregation of duties are formally defined, documented, and communicated to all relevant personnel.	☒ Yes ☐ No ☐ NA	
5.1.6	The supplier shall maintain and make available to HCT a current register of all applicable regulatory, legal, and contractual compliance obligations relevant to information security.	☒ Yes ☐ No ☐ NA	
5.1.7	The supplier shall conduct formal security programme reviews at least annually with supplier's senior management sign-off.	☒ Yes ☐ No ☐ NA	
5.1.8	The supplier shall maintain a security metrics programme and report agreed KPIs/KRIs to HCT on a periodic basis as agreed.	☒ Yes ☐ No ☐ NA	
5.1.9	The supplier shall ensure that all subcontractors and sub-processors are bound by information security obligations no less stringent than those imposed on the supplier by HCT.	☒ Yes ☐ No ☐ NA	

5.2.1	The supplier shall operate a documented information security risk management process aligned with an accepted framework (e.g., ISO 27001, UAE IA) covering identification, assessment, treatment, and monitoring of risks.	☒ Yes ☐ No ☐ NA	
5.2.2	The supplier shall conduct a formal risk assessment (aligned with HCT's IS Risk Management Processes) at least annually and whenever significant changes are made to systems, processes, or the threat landscape pertinent to services provided to HCT.	☒ Yes ☐ No ☐ NA	
5.2.3	The supplier shall maintain a risk register capturing identified risks, likelihood, impact, risk owners, treatment decisions, remediation timelines and residual risk levels pertinent to services provided to HCT.	☒ Yes ☐ No ☐ NA	
5.2.4	The supplier shall define and apply a documented risk acceptance process requiring appropriate senior management authorisation for all accepted risks (pertinent to services provided to HCT) above a defined threshold. [Risk acceptance in this context refers to the time between the identification of the risks and mitigation of the risks.]	☒ Yes ☐ No ☐ NA	
5.2.5	The supplier shall communicate material security risks that may affect HCT's data, operations, or regulatory standing immediately after confirmation.	☒ Yes ☐ No ☐ NA	
5.2.6	The solution shall incorporate security risk considerations in the design, development, operations, and change management lifecycle (Security by Design).	☒ Yes ☐ No ☐ NA	
5.3.1	The solution shall support seamless integration with the HCT Identity and Access Management (IAM) solution.	☒ Yes ☐ No ☐ NA	
5.3.2	The solution shall support role-based access control (RBAC), allowing HCT to assign permissions based on user roles and the principle of least privilege.	☒ Yes ☐ No ☐ NA	
5.3.3	The solution shall support multi-factor authentication (MFA) for all user access to the solution, particularly for privileged, administrative, and remote access.	☒ Yes ☐ No ☐ NA	

5.3.4	The solution shall implement a formal access provisioning and de-provisioning process ensuring access rights are revoked promptly (within 24 hours for terminations) upon role change or departure.	☒ Yes ☐ No ☐ NA	
5.3.5	The solution shall enforce strong authentication policies including minimum password complexity, length (minimum 14 characters), and account lockout after a configurable number of failed attempts.	☒ Yes ☐ No ☐ NA	
5.3.6	The solution shall support integration with HCT's identity provider (e.g., Microsoft Entra ID / Azure AD) via SAML 2.0 or OpenID Connect (OIDC) for Single Sign-On (SSO).	☒ Yes ☐ No ☐ NA	
5.3.7	The supplier shall conduct formal access reviews at least every six months (quarterly for privileged accounts) to validate all user access rights remain appropriate.	☒ Yes ☐ No ☐ NA	
5.3.8	The solution shall enforce separate privileged access mechanisms (e.g., PAM) for administrative and service accounts, with full session logging.	☒ Yes ☐ No ☐ NA	
5.3.9	The solution shall not permit shared or generic user accounts; all accounts shall be uniquely attributable to an individual.	☒ Yes ☐ No ☐ NA	
5.3.10	The solution shall automatically terminate or lock inactive user sessions after a configurable inactivity timeout period.	☒ Yes ☐ No ☐ NA	
5.2.11	All default vendor-supplied credentials shall be changed before delivery or first use. No hardcoded credentials may exist in any delivered component.	☒ Yes ☐ No ☐ NA	
5.4.1	All HCT data must be encrypted in transit using TLS 1.2 or higher. TLS 1.0 and 1.1 must be disabled.	☒ Yes ☐ No ☐ NA	
5.4.2	All HCT data stored at rest must be encrypted using AES-256 or an equivalent approved cipher.	☒ Yes ☐ No ☐ NA	
5.4.3	HCT data must be stored and processed only within data centres or regions explicitly approved by HCT in writing. Cross- border data transfers require prior HCT approval.	☒ Yes ☐ No ☐ NA	

5.4.4	Upon contract termination or at HCT's request, all HCT data must be returned in a usable format and then securely and verifiably deleted from all vendor systems within 30 days.	☒ Yes ☐ No ☐ NA	
5.4.5	The vendor must not use HCT data for any purpose other than service delivery (e.g., no use for training AI models, analytics, or advertising).	☒ Yes ☐ No ☐ NA	
5.4.6	The solution shall support configurable data retention periods aligned with HCT's requirements, and shall be capable of enforcing automated deletion at end of retention.	☒ Yes ☐ No ☐ NA	
5.4.7	The supplier shall handle data in accordance with controls aligned with HCT data classification scheme.	☒ Yes ☐ No ☐ NA	
5.4.8	HCT data shall be stored and processed within data centres and regions explicitly approved by HCT in writing. Cross-border data transfers require prior HCT approval.	☒ Yes ☐ No ☐ NA	
5.4.9	The supplier shall process personal data only in accordance with HCT's documented instructions and applicable data protection laws.	☒ Yes ☐ No ☐ NA	
5.4.10	The supplier shall maintain a current Record of Processing Activities (RoPA) covering all personal data processed on behalf of HCT.	☒ Yes ☐ No ☐ NA	
5.4.11	The solution shall enforce data minimisation principles, collecting and retaining only the minimum personal data necessary.	☒ Yes ☐ No ☐ NA	
5.4.12	The supplier shall implement and maintain documented data retention and secure disposal policies, ensuring data is deleted or destroyed in a verifiable manner.	☒ Yes ☐ No ☐ NA	
5.4.13	The solution shall provide mechanisms to fulfil Data Subject Access Requests (DSARs), right to erasure, and other data subject rights within legally required timeframes.	☒ Yes ☐ No ☐ NA	
5.4.14	The supplier shall conduct Data Protection Impact Assessments (DPIAs) for high-risk processing activities.	☒ Yes ☐ No ☐ NA	

5.4.15	The solution shall prevent unauthorised copying, printing, downloading, or exfiltration of classified data through technical controls (e.g., DLP, access restrictions).	☒ Yes ☐ No ☐ NA	
5.4.16	The supplier shall immediately notify HCT of any personal data breach within the timeframes specified in the contract.	☒ Yes ☐ No ☐ NA	
5.5.1	The solution shall implement network segmentation and zoning principles to separate production, development, and testing environments and to isolate sensitive system components from less trusted networks.	☒ Yes ☐ No ☐ NA	
5.5.2	The solution shall deploy and maintain next-generation firewalls (NGFW) with documented, reviewed, and approved rule sets.	☒ Yes ☐ No ☐ NA	
5.5.3	The solution shall enforce encrypted communications for all data in transit using TLS 1.2 or higher and disable deprecated protocols.	☒ Yes ☐ No ☐ NA	
5.5.4	The solution shall implement intrusion detection and/or prevention systems (IDS/IPS) to detect and alert on or block malicious network activity.	☒ Yes ☐ No ☐ NA	
5.5.5	The solution shall secure all remote access to internal systems via approved encrypted VPN or ZTNA mechanisms with MFA enforced.	☒ Yes ☐ No ☐ NA	
5.5.6	The supplier shall maintain and regularly review network architecture documentation, including data flow diagrams.	☒ Yes ☐ No ☐ NA	
5.5.6	The solution shall implement DNS security controls (DNSSEC, DNS filtering) and email security standards (SPF, DKIM, DMARC).	☒ Yes ☐ No ☐ NA	
5.5.7	The solution shall prohibit unauthorised wireless access points and enforce security controls (WPA3, 802.1X) on approved wireless networks.	☒ Yes ☐ No ☐ NA	
5.5.8	The solution shall implement DDoS mitigation controls or services to protect the availability of internet-facing services.	☒ Yes ☐ No ☐ NA	